Universidad de Palermo

ESTÁNDARES Y NORMATIVAS DE SEGURIDAD

Introducción a la Ciberseguridad y la Conformidad

Profesor: Fabián Descalzo

Adquirir los conocimientos necesarios para la planificación, implementación, gestión, control y mantenimiento de la seguridad de la información. Obtener los conocimientos necesarios para aplicar las mejores prácticas para una gestión de Ciberseguridad.

- Nos conocemos
- ¿Qué expectativas tengo de esta materia?
- Participación y comentarios
- 2 Break de 15 minutos cada uno
- La clase se graba, y queda disponible por 30 días

LinkedIn: https://linkedin.com/in/fabiandescalzo
Grupo Linkedin: https://www.linkedin.com/groups/12188431/
https://www.instagram.com/fabiandescalzo/
Slide Share: https://slideshare.net/fabiandescalzo
Twitter: https://www.twitter.com/fabiandescalzo
YouTube: https://www.youtube.com/fabdescalzo
BDO Argentina: bdoargentina.com



FABIÁN DESCALZO

Socio de la práctica de Ciberseguridad, Gobierno Tecnológico y Digital Risk Advisory Services de BDO en Argentina y Líder de la práctica de ciberseguridad para LATAM, con 35 años de experiencia en el área de gestión e implementación de Gobierno de Seguridad de la Información, Gobierno de TI, Compliance y Auditoría de TI en Argentina y Latinoamérica, y asesoramiento para el cumplimiento de Leyes y Normativas Nacionales e Internacionales en compañías de primer nivel de diferentes áreas de negocio.

Docente Universitario y de Sistemas de Gestión IT, Seguridad de la Información y Auditoría IT para TÜV Rheinland. Conferencista internacional y columnista en medios especializados.

Autoridad del Comité de Seguridad Patrimonial y Seguridad de la Información en AmCham Argentina, Miembro Titular del Comité Directivo y Presidente de la Comisión de Educación de ISACA Buenos Aires Chapter, de la Asociación Latinoamericana de Privacidad, de la Asociación Argentina de Ética y Compliance, y del Comité Científico del IEEE (Institute of Electrical and Electronics Engineers)



Fabian Descalzo

Socio de Ciberseguridad y Gobierno Tecnológico Cybersecurity Líder región LATAM

Preparación Académica

- **Licenciatura en Administración de Sistemas (UNIVERSIDAD DE LA MARINA MERCANTE)**
- **CERTIFICACION EN DIRECCION DE SEGURIDAD DE LA INFORMACION (UNIVERSIDAD CAECE)**
- **CSX Cybersecurity Proffesional (ISACA Buenos Aires Chapter)**
- **Implementer ISO/IEC 31000 (TÜV Rheinland)**
- **COBIT5 Foundation (CN 02363587-01-2EVV)**
- **Lead Auditor ISO/IEC 20000:2011 (CN 17-6510)**
- **Lead Auditor ISO/IEC 22301:2019 (CN 19-3478); IRCA ISMS Auditor**
- **Lead Auditor ISO/IEC 27001 (CN IT2566710)**
- **ITIL® version 3:2011, Information Management (EXN4396338)**
- **ITIL® version 3:2011, Accredited Trainer (EXIN Accreditation)**

Competencias

- Autor del primer Convertion course para auditores líder ISO/IEC 27001 A ISO/IEC 20000
- Autor del primer Convertion course para auditores líder ISO/IEC 9001/27001/20000 A ISO/IEC 22301
- Docente universitario y en Sistemas de Gestión IT, Seguridad de la Información y Auditoría IT para TÜV Rheinland.
- Autoridad del Comité de Seguridad Patrimonial y Seguridad de la Información en AmCham Argentina, Miembro Titular del Comité Directivo y Presidente de la Comisión de Educación de ISACA Buenos Aires Chapter, de la Asociación Latinoamericana de Privacidad, de la Asociación Argentina de Ética y Compliance, y del Comité Científico del IEEE (Institute of Electrical and Electronics Engineers)

Socio de la práctica de Ciberseguridad, Gobierno Tecnológico y Digital Risk Advisory Services de BDO en Argentina, con más de 30 años de experiencia en el área de gestión e implementación de Gobierno de Seguridad de la Información, Gobierno de TI, Compliance IT y Auditoría TI en Argentina y Latinoamérica.

fdescalzo@bdoargentina.com

linkedin.com/in/fabiandescalzo

+54 9 11 4106 7000

BIENVENIDOS A BDO CYBERSECURITY LATAM

El objetivo principal de la práctica es asegurar la transformación digital y la adaptación constante de las organizaciones en el uso de la tecnología, mediante la implementación de soluciones estratégicas para asegurar los objetivos de negocio de nuestros Clientes, preparándolos para responder a las necesidades de innovación en forma segura y bajo sus necesidades de cumplimiento



LÍNEA DE TIEMPO

LA RELACIÓN ENTRE LA TECNOLOGÍA Y LOS DATOS

De los primeros registros a la era de la inteligencia artificiial:
los datos siempre han impulsado la evolución tecnológica.



Antes de 1950
Datos Manuales

La información se registraba en papel.

Los datos eran limitados, difíciles de almacenar, buscar y compartir.

TECNOLOGÍA CLAVE

Escritura, libros, archivos físicos

1950 - 1970
Computación Temprana

Las computadoras permitieron almacenar y procesar datos de forma más rápida.

Nacen las bases de datos y los sistemas de gestión.

TECNOLOGÍA CLAVE

Mainframes, cintas magnéticas, bases de datos jerárquicas

1970 - 1990
Digitalización y Expansión

La digitalización transforma los datos en el centro de las organizaciones.

Aumenta la capacidad de almacenamiento y procesamiento.

TECNOLOGÍA CLAVE

PCs, bases de datos relacionales, redes empresariales

1990 - 2000
Internet y Nuevas Posibilidades

Internet conecta al mundo y multiplica la creación y el intercambio de datos.

Surgen los datos web, el comercio electrónico y los portales.

TECNOLOGÍA CLAVE

Internet, servidores web, e-commerce, ERP, CRM

2000 - 2010
Big Data y Movilidad

Explosión de datos estructurados y no estructurados.

Dispositivos móviles y sensores generan datos en tiempo real.

TECNOLOGÍA CLAVE

Big Data, nube, dispositivos móviles, redes sociales, IoT

2010 - 2020
Análisis Avanzado y Nube

Los datos se analizan a gran escala para generar insights y tomar mejores decisiones.

La nube permite escalabilidad y acceso global.

TECNOLOGÍA CLAVE

Cloud computing, analítica avanzada, machine learning

2020 - Hoy
Inteligencia Artificial y Datos como Activo Estratégico

La IA aprende de los datos y automatiza procesos.

Los datos se convierten en el recurso más valioso para innovar y crear valor.

TECNOLOGÍA CLAVE

Inteligencia artificial, IA generativa, edge computing, data fabric

EVOLUCIÓN DE GUÍAS, ESTÁNDARES Y NORMAS SOBRE SEGURIDAD DE LA INFORMACIÓN

De 1970 a la actualidad

1970 — Primeros principios de seguridad en sistemas

Nacen los primeros conceptos de protección de datos en entornos informáticos.

1983 — TCSEC ("Orange Book")

El estándar del Departamento de Defensa de EE. UU. para evaluación de seguridad de sistemas informáticos.

1985 — Infosec Policy Manual (Shell International)

Shell publica su manual corporativo de políticas de seguridad de la información, pionero en la gestión formal de la seguridad.

1989 — ISO/IEC 27002 (Código de Prácticas)

Primer código de prácticas para la gestión de la seguridad de la información.

1991–1994 — Iniciativas en el Reino Unido

El gobierno del Reino Unido impulsa la concienciación y buenas prácticas en seguridad de la información.

1995 — BS 7799 Partes 1 y 2

Publicación del estándar británico para la gestión de la seguridad de la información.

2000 — ISO/IEC 17799

Adoptado internacionalmente como código de prácticas para la gestión de la seguridad.

2005 — ISO/IEC 27001:2005

Primera versión del estándar para Sistemas de Gestión de Seguridad de la Información (SGSI).

2005 — ISO/IEC 27002:2005

Primera revisión del código de prácticas, con 11 dominios de control.

2013 — ISO/IEC 27001:2013

Segunda versión del estándar SGSI, alineada con la estructura de alto nivel (HLS).

2022 — ISO/IEC 27001:2022 ISO/IEC 27002:2022

Últimas versiones con enfoque en riesgos, amenazas actuales y ciberresiliencia.

2024+ — Actualidad (2023–2024+)

Enfoque en marcos integrados, resiliencia operacional, privacidad, IA segura y gestión de riesgos en la nube y la cadena de suministro.

GUÍAS Y ESTÁNDARES RELACIONADOS

- **1983 — NIST SP 500-18** (Guía de Seguridad para Sistemas de Información)
- **1985 — COBIT 1.0** Marco de gobernanza de TI y control.
- **1989 — UK Gov. Green Paper "Information Assurance"**
- **1991–1994 — ITSEC** Evaluación de seguridad de TI (Normalización en Europa)
- **1995 — ISO/IEC TR 13335** (Guía para la gestión de la seguridad de TI)
- **2000 — ISO/IEC TS408 (Criterios Comunes)** Estándar para evaluación de seguridad de productos de TI.
- **2005 — ISO/IEC 27005** (Gestión de riesgos de seguridad de la información)
- **2005 — ISO/IEC 27017** (Controles de seguridad para servicios en la nube)
- **2013 — ISO/IEC 27018** (Protección de datos personales en la nube)
- **2024+ — NIST Cybersecurity Framework (2014)** Adoptado globalmente para gestionar y mejorar la ciberseguridad.

¿QUÉ REPRESENTAN?

GUÍAS
Documentos con recomendaciones y mejores prácticas para la protección de la información.

ESTÁNDARES
Documentos consensuados que establecen requisitos y especificaciones para asegurar la calidad y seguridad.

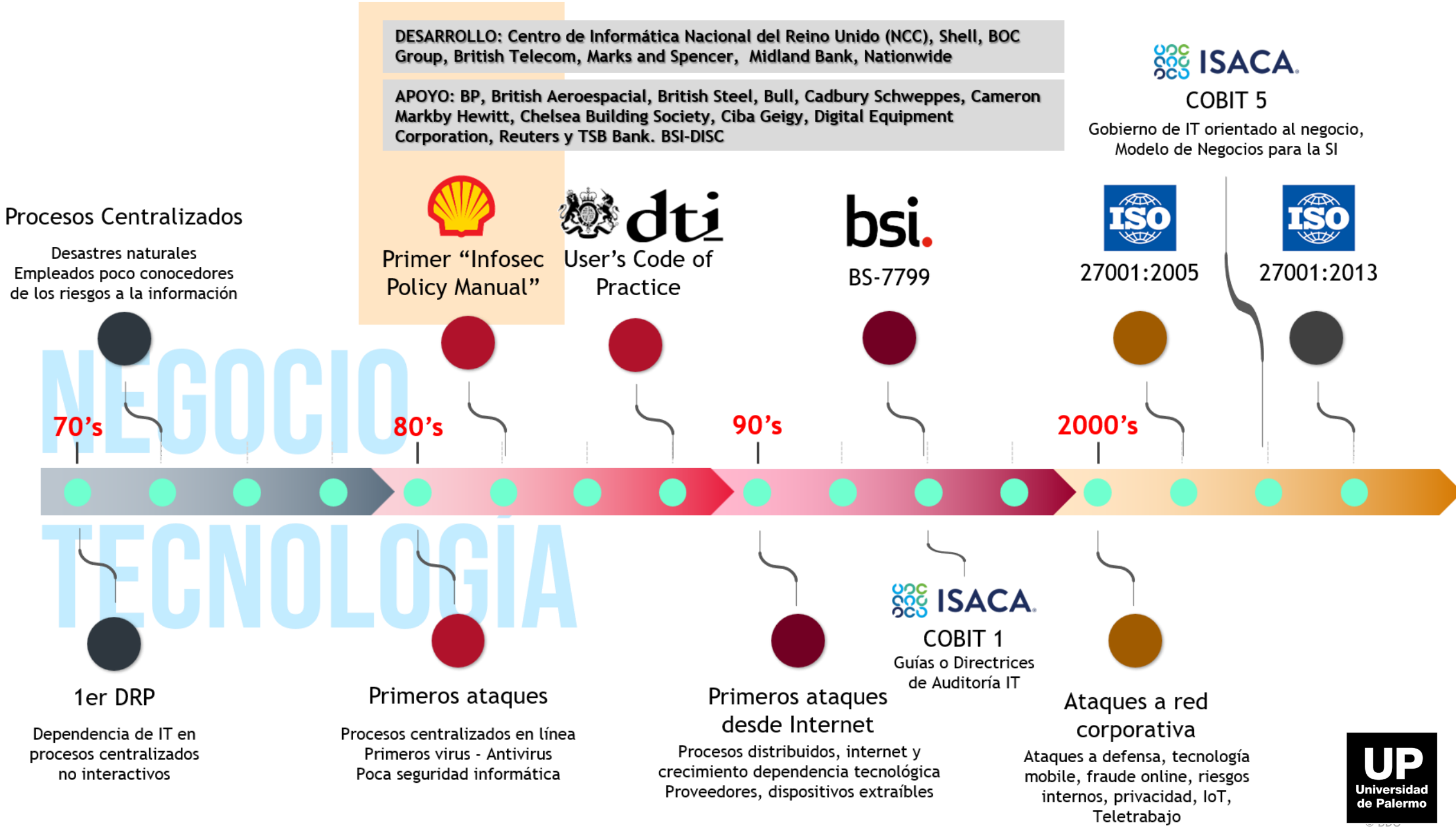
NORMAS
Estándares adoptados formalmente por organismos de normalización (ISO, IEC) con posibilidad de certificación.

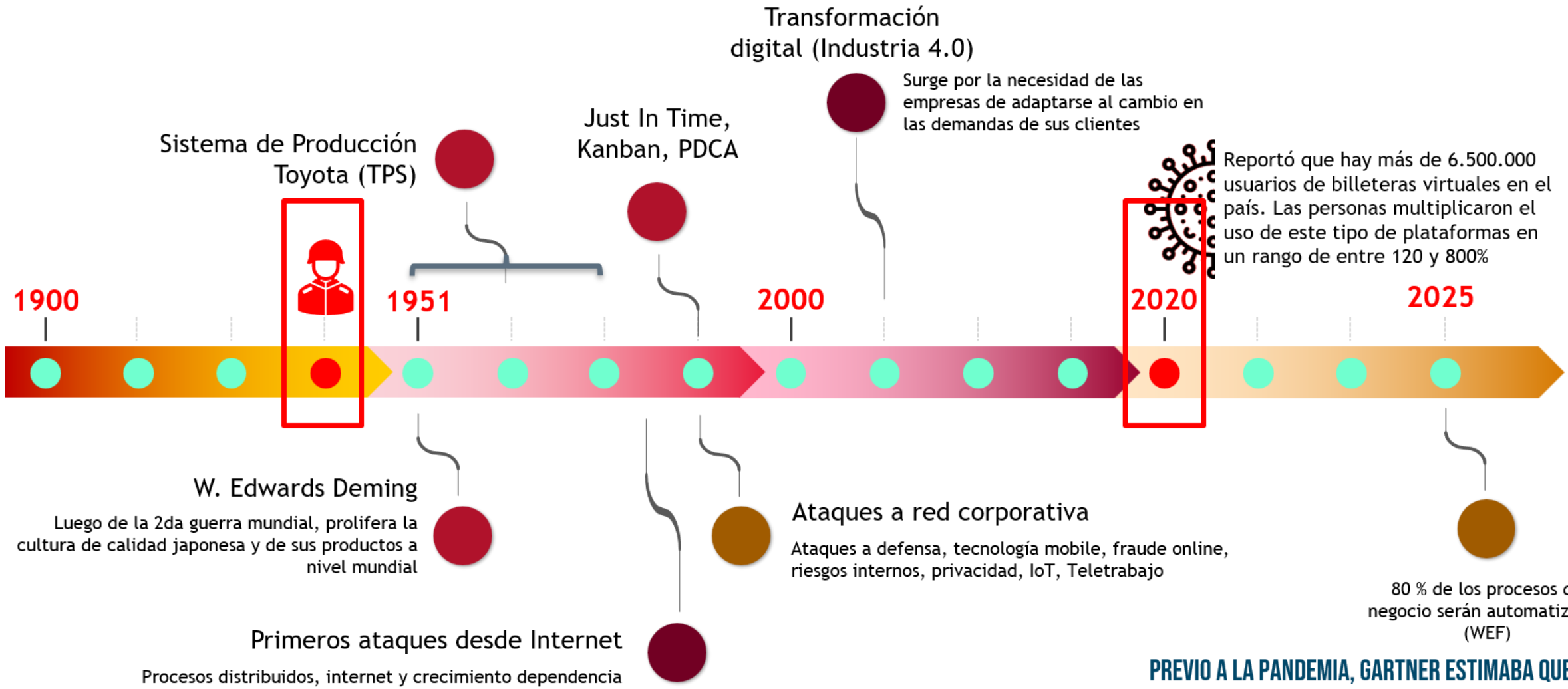
OBJETIVO
Proteger la confidencialidad, integridad y disponibilidad de la información, minimizando riesgos y generando confianza.

TENDENCIA ACTUAL
Hacia marcos integrados, gestión de riesgos empresariales, privacidad, resiliencia operacional e IA responsable.

La seguridad de la información es un campo en constante evolución. Mantenerse actualizado con las mejores prácticas y estándares es clave para enfrentar los desafíos actuales y futuros.

Fuente: ISO, NIST, BSI, ENISA, ISACA y publicaciones oficiales.


DESARROLLO: Centro de Informática Nacional del Reino Unido (NCC), Shell, BOC Group, British Telecom, Marks and Spencer, Midland Bank, Nationwide
APOYO: BP, British Aeroespacial, British Steel, Bull, Cadbury Schweppes, Cameron Markby Hewitt, Chelsea Building Society, Ciba Geigy, Digital Equipment Corporation, Reuters y TSB Bank. BSI-DISC
ISACA
COBIT 5
Gobierno de IT orientado al negocio, Modelo de Negocios para la SI
Procesos Centralizados
Desastres naturales
Empleados poco conocedores de los riesgos a la información
Primer "Infosec Policy Manual"
User's Code of Practice
BS-7799
27001:2005
27001:2013
NEGOCIO
TECNOLOGÍA
70's
80's
90's
2000's
1er DRP
Dependencia de IT en procesos centralizados no interactivos
Primeros ataques
Procesos centralizados en línea
Primeros virus - Antivirus
Poca seguridad informática
Primeros ataques desde Internet
Procesos distribuidos, internet y crecimiento dependencia tecnológica
Proveedores, dispositivos extraíbles
ISACA
COBIT 1
Guías o Directrices de Auditoría IT
Ataques a red corporativa
Ataques a defensa, tecnología mobile, fraude online, riesgos internos, privacidad, IoT, Teletrabajo
UP
Universidad de Palermo



PREVIO A LA PANDEMIA, GARTNER ESTIMABA QUE EN 2020 EL 60% DE LOS NEGOCIOS DIGITALES SUFRIRÁN GRANDES FALLOS DE SEGURIDAD

UP Universidad de Palermo

NEGOCIO

TECNOLOGÍA

DATOS

Capacidad Tecnológica

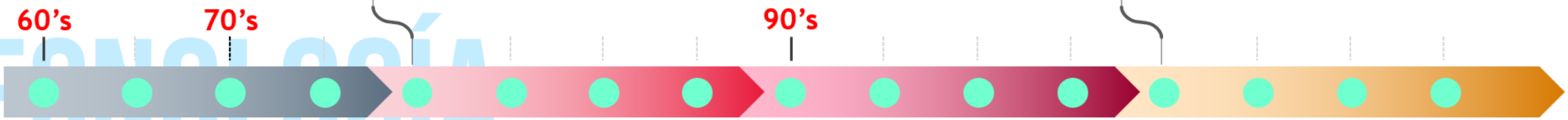
Mayor capacidad que hace que cada 40 meses se duplique el almacenamiento de datos

Se define el crecimiento constante de datos como una oportunidad y un reto para investigar en el volumen, la velocidad y la variedad

"Big data representa los activos de información caracterizados por un volumen, velocidad y variedad tan altos que requieren una tecnología específica y métodos analíticos para su transformación en valor"

Dependencia de IT en procesos centralizados no interactivos

Procesos distribuidos, internet y crecimiento dependencia tecnológica
Proveedores, dispositivos extraíbles



Procesos centralizados en línea
Primeros virus - Antivirus
Poca seguridad informática

Ataques a defensa, tecnología mobile, fraude online, riesgos internos, privacidad, IoT, Teletrabajo

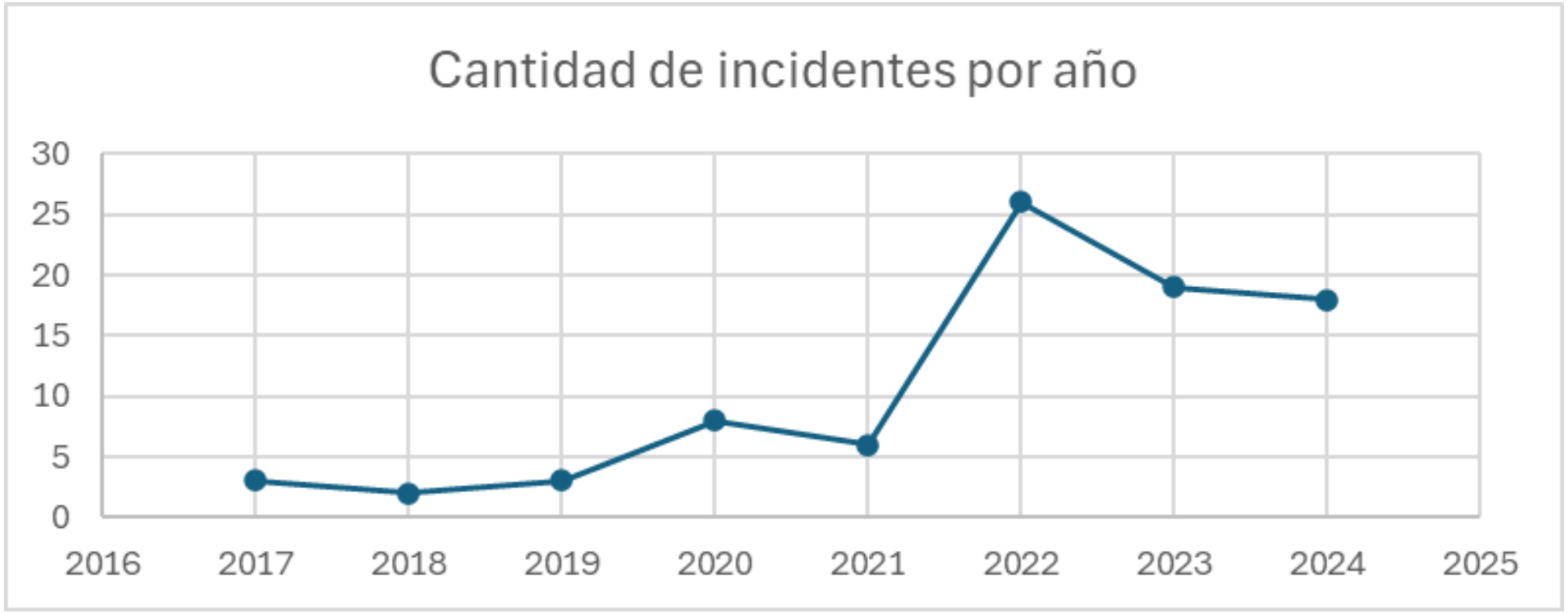
Almacenes de datos

Data Warehouse: Entregar la información correcta a la gente indicada en el momento óptimo y en el formato adecuado

Inicio BIG DATA

Cantidad de datos tal que supera la capacidad del software convencional para ser capturados, administrados y procesados en un tiempo razonable

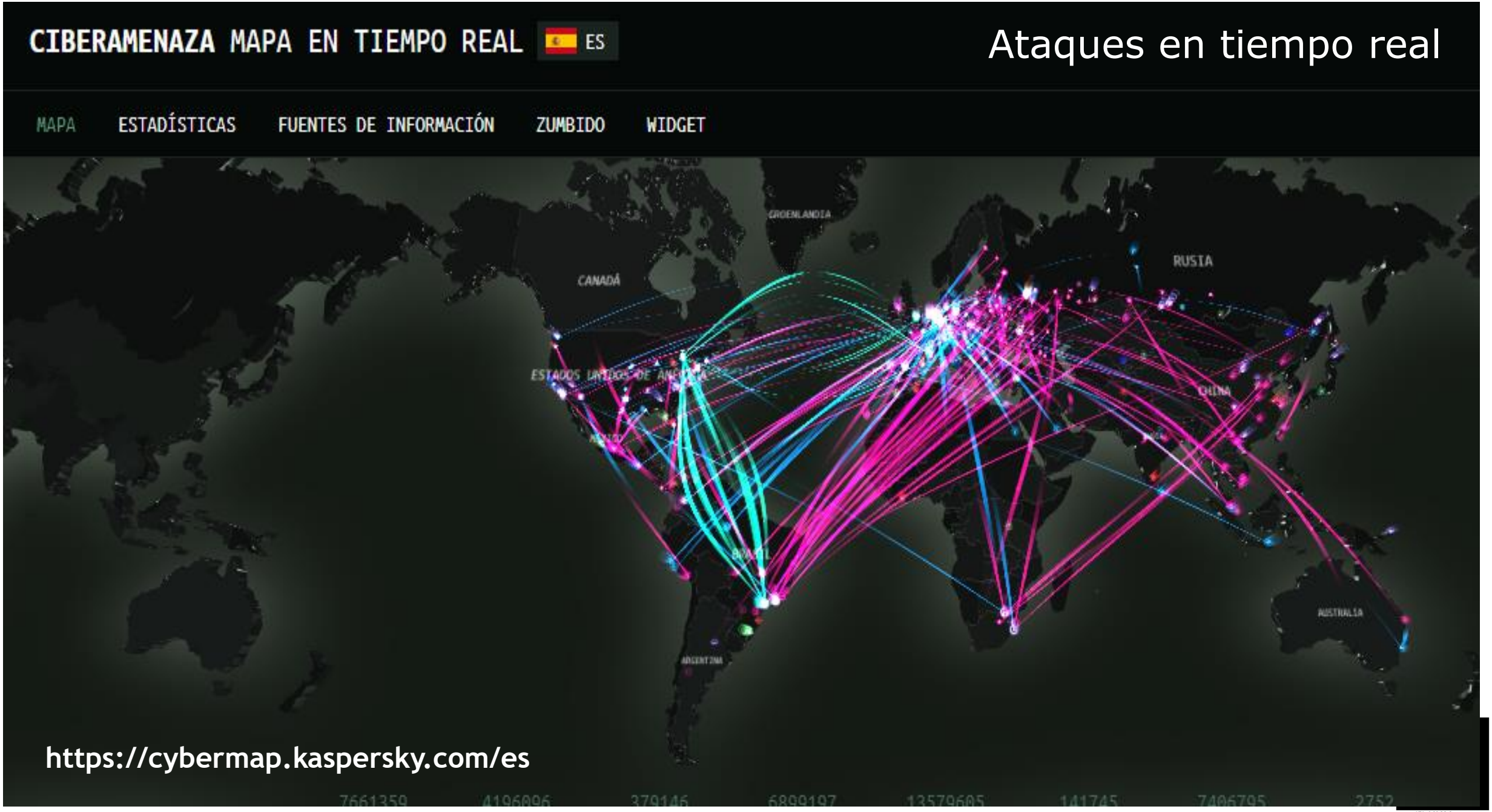
UP Universidad de Palermo

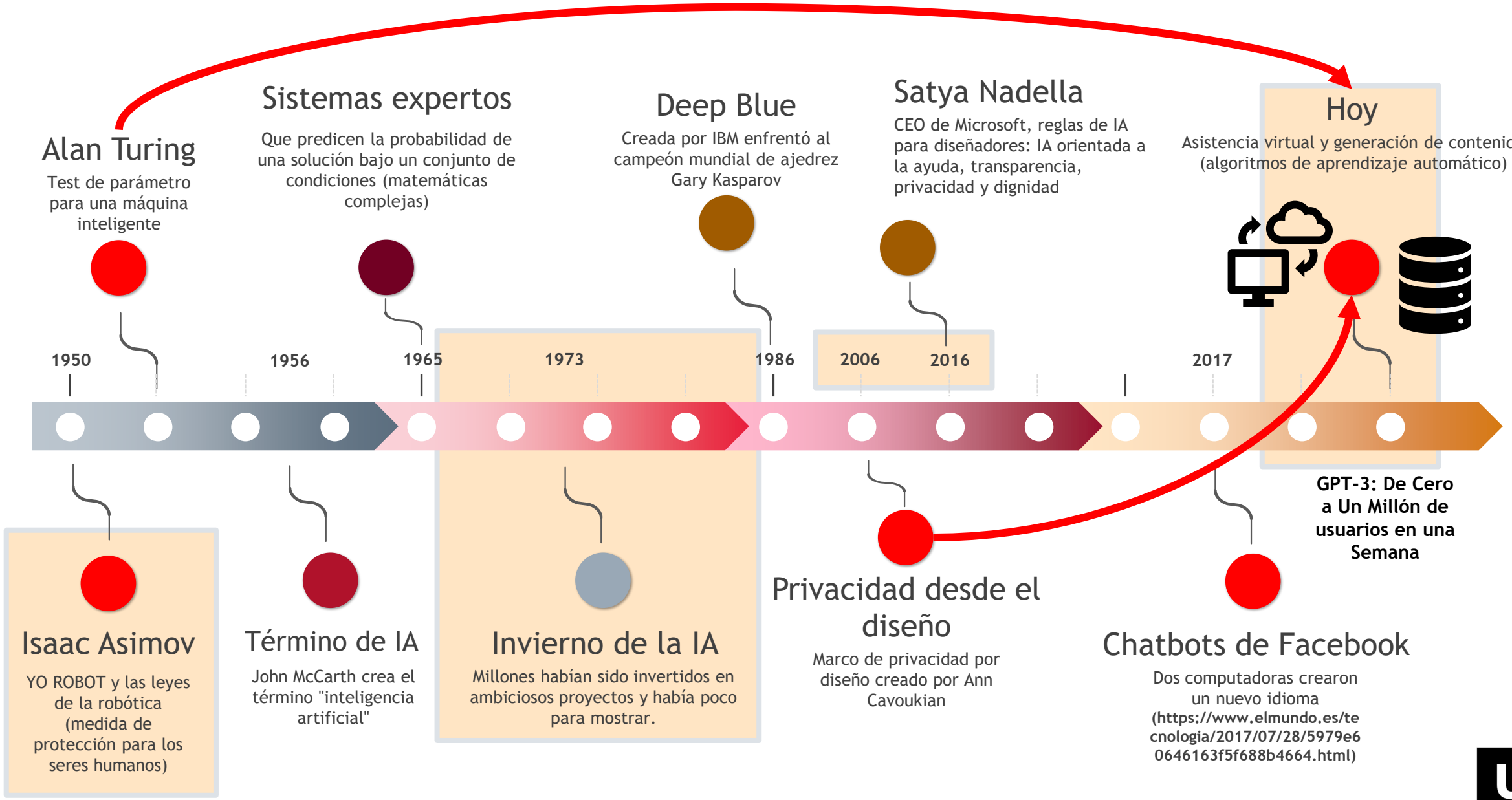


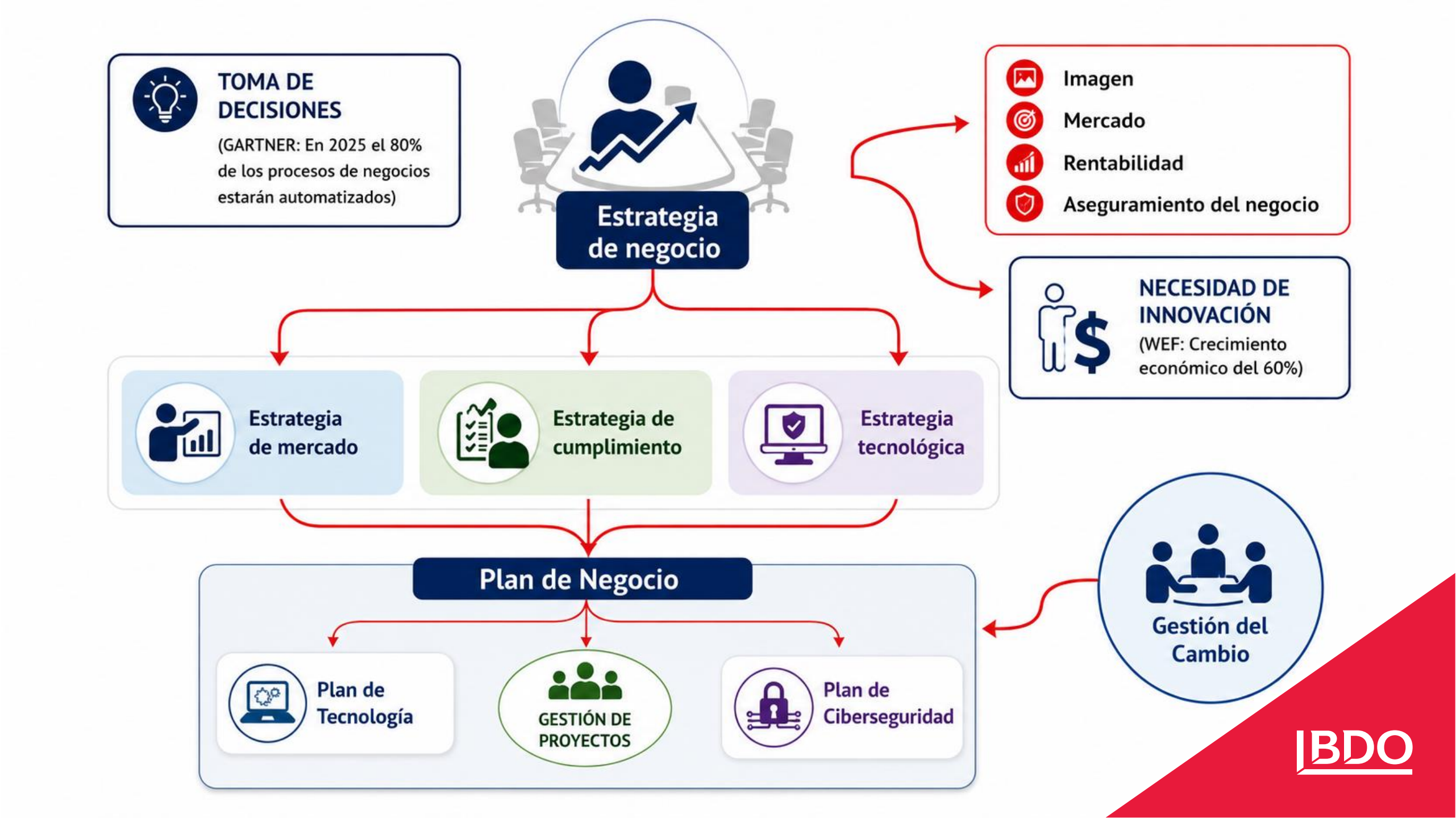
- Durante 2021 y 2022, hubo un aumento significativo de los ciberataques.
- El 41% de las pymes en el país sufrieron algún tipo de ataque cibernético en el último año.
- Según el Foro Económico Mundial, se estima que el costo promedio global de un ciberataque grave puede alcanzar los $4.45 millones de dólares
- Tras el pago frente a un ransomware, únicamente un 36% recuperó todos sus datos

UP Universidad de Palermo

Ataques en tiempo real




Alan Turing
Test de parámetro para una máquina inteligente
Sistemas expertos
Que predicen la probabilidad de una solución bajo un conjunto de condiciones (matemáticas complejas)
Deep Blue
Creada por IBM enfrentó al campeón mundial de ajedrez Gary Kasparov
Satya Nadella
CEO de Microsoft, reglas de IA para diseñadores: IA orientada a la ayuda, transparencia, privacidad y dignidad
Hoy
Asistencia virtual y generación de contenido (algoritmos de aprendizaje automático)
1950
1956
1965
1973
1986
2006
2016
2017
Isaac Asimov
YO ROBOT y las leyes de la robótica (medida de protección para los seres humanos)
Término de IA
John McCarth crea el término "inteligencia artificial"
Invierno de la IA
Millones habían sido invertidos en ambiciosos proyectos y había poco para mostrar.
Privacidad desde el diseño
Marco de privacidad por diseño creado por Ann Cavoukian
Chatbots de Facebook
Dos computadoras crearon un nuevo idioma (https://www.elmundo.es/tecnologia/2017/07/28/5979e60646163f5f688b4664.html)
GPT-3: De Cero a Un Millón de usuarios en una Semana


TOMA DE DECISIONES
(GARTNER: En 2025 el 80% de los procesos de negocios estarán automatizados)
Estrategia de negocio
Imagen
Mercado
Rentabilidad
Aseguramiento del negocio
NECESIDAD DE INNOVACIÓN
(WEF: Crecimiento económico del 60%)
Estrategia de mercado
Estrategia de cumplimiento
Estrategia tecnológica
Plan de Negocio
Plan de Tecnología
GESTIÓN DE PROYECTOS
Plan de Ciberseguridad
Gestión del Cambio
BDO

“La estrategia digital impulsa el negocio, pero amplifica el riesgo”



Estrategia de mercado

Estrategia de cumplimiento

Estrategia tecnológica

Riesgo de control interno

- **Ciberseguridad como riesgo material**
- Mayor regulación y multas sobre los datos personales
- Impacto por falta de resiliencia en el negocio
- Falta de formalización o mejoras en el tratamiento de riesgos

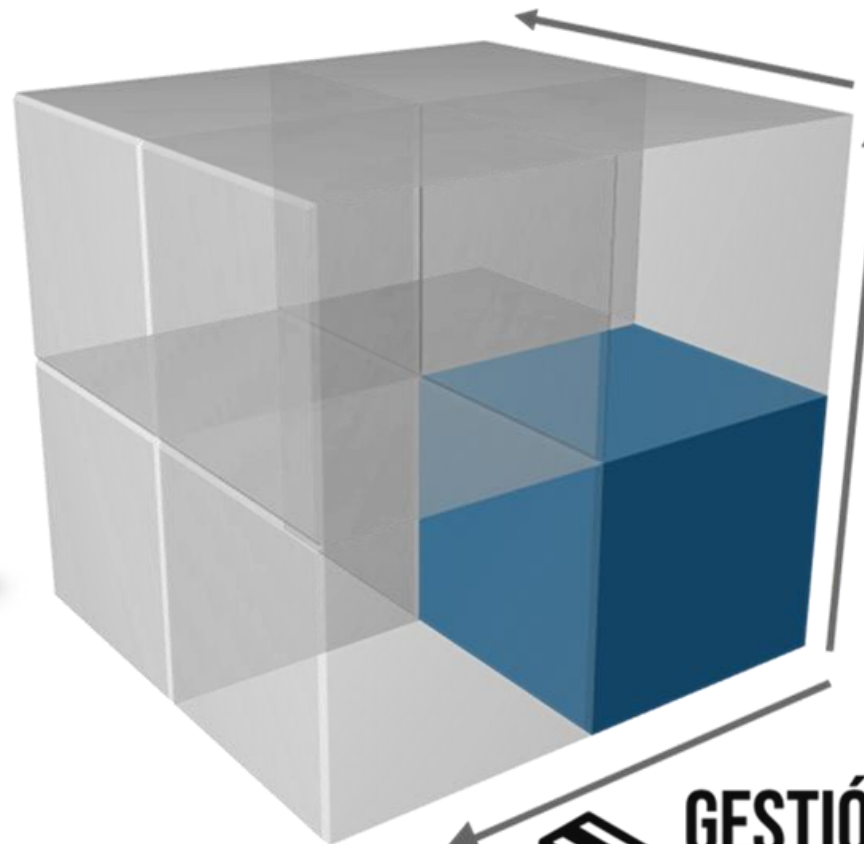
UP Universidad de Palermo

PLANIFICACIÓN ESTRATÉGICA Y GRADO DE INNOVACIÓN



CUBO DEL GOBIERNO TECNOLÓGICO

CIBERATAQUES O AMENAZAS A LA INFORMACIÓN EN LA AUTOMATIZACIÓN DE PROCESOS



TECNOLOGÍA

Grado de innovación en el desarrollo tecnológico (tecnologías y procesos de producción)

ENTORNO

Grado de innovación en lo requerido para el crecimiento del negocio

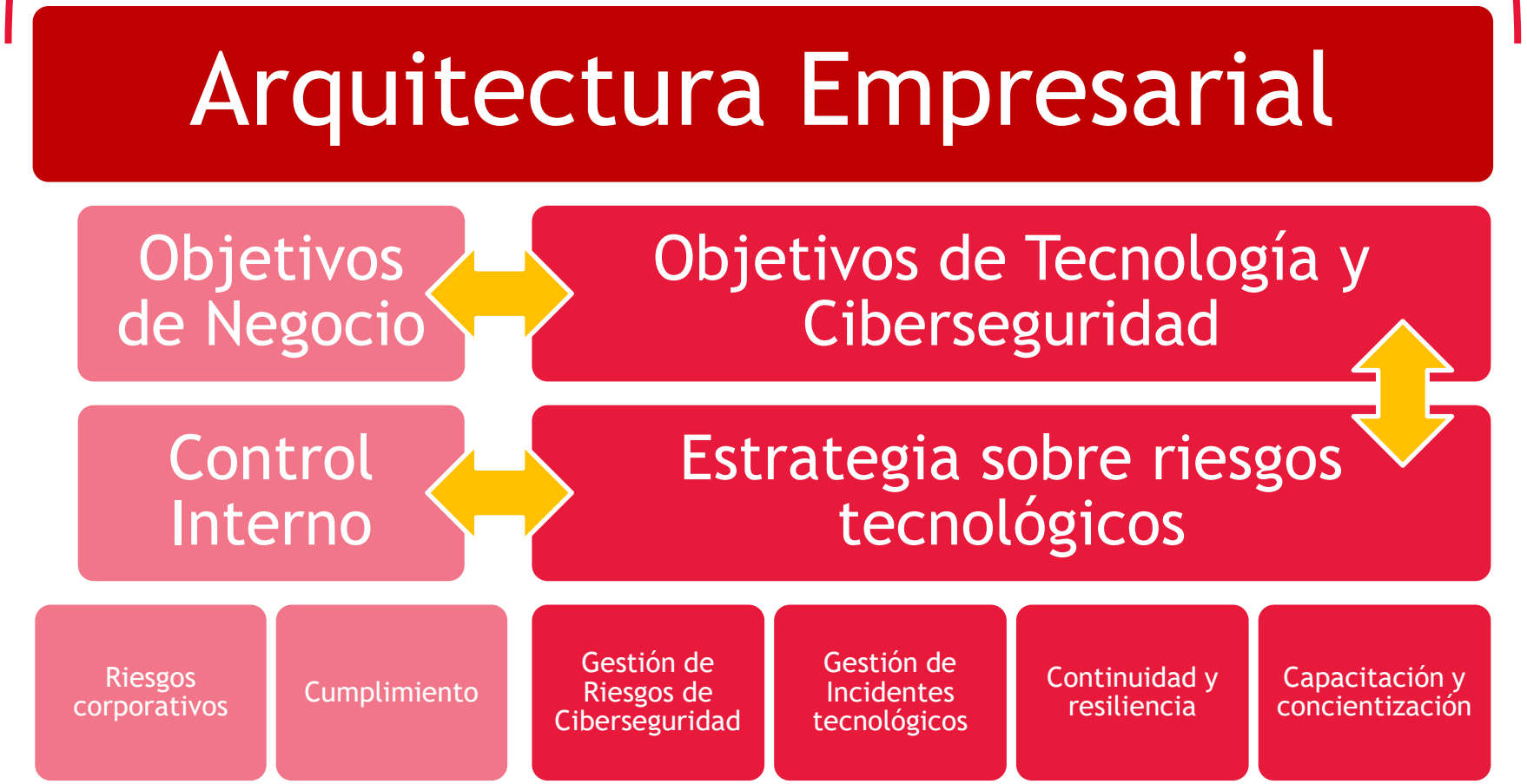
GESTIÓN

Grado de innovación necesaria en la gestión para el desarrollo del negocio

UP Universidad de Palermo

CONFIANZA DIGITAL

COMPLIANCE DIGITAL



Propiedades

- Gestión de riesgos de ciberseguridad
- Aseguramiento de los procesos de negocio frente a la tecnología
- Resiliencia organizacional
- Integridad de los datos y aseguramiento de la transparencia
- Protección de la privacidad de las partes interesadas
- Cumplimiento de leyes, regulaciones y control interno

UP Universidad de Palermo

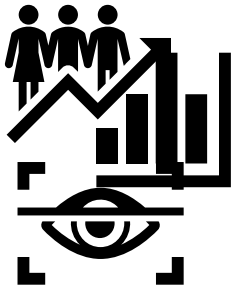
OBSOLESCENCIA NORMATIVA



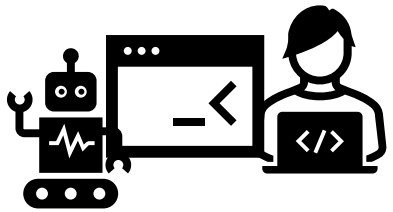
Tratamiento de la tecnología

Ciberincidentes





Gestión de los datos



Ciclo de vida de desarrollo

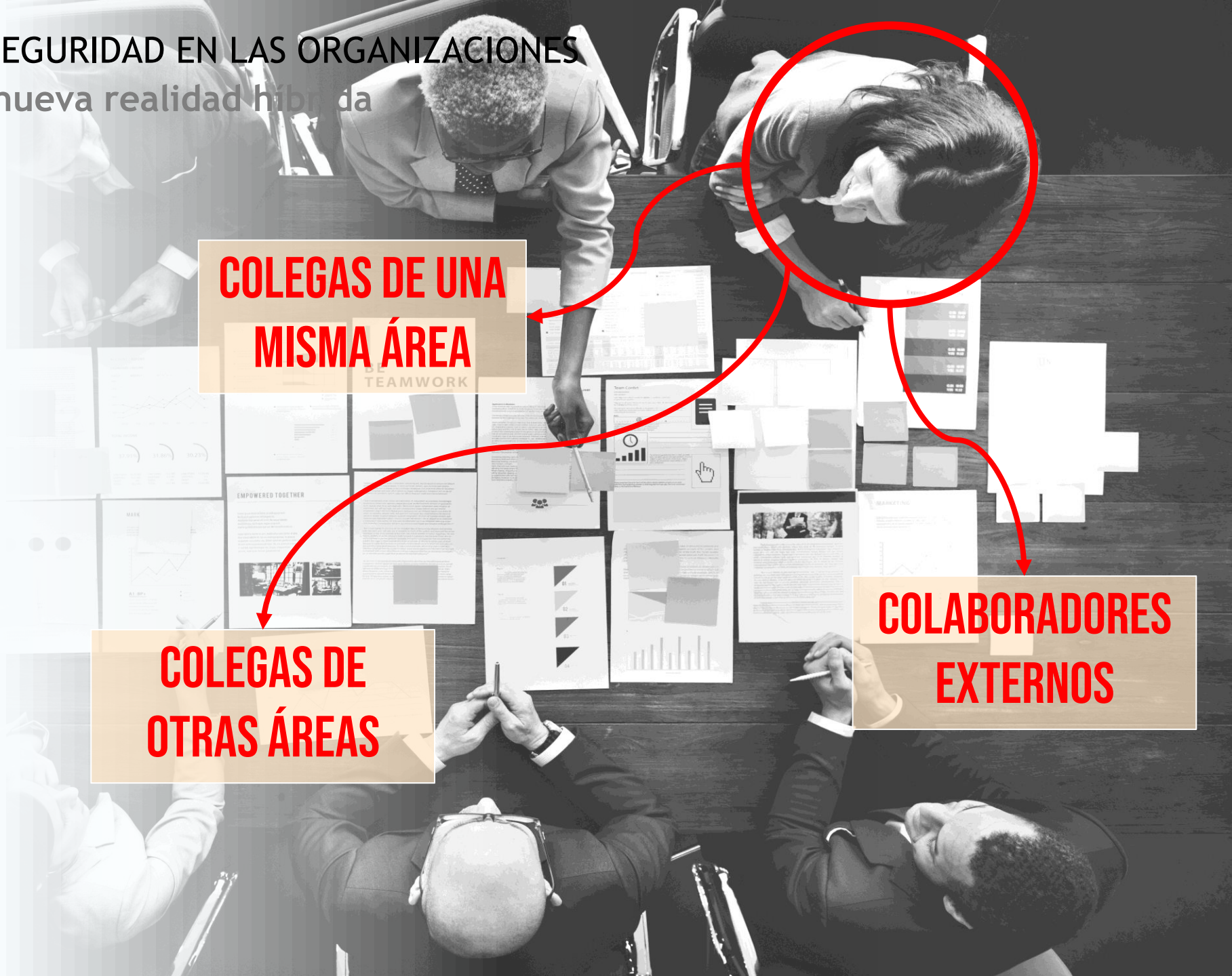
UP Universidad de Palermo

27001:2022 INFORMATION SECURITY ~~TECHNOLOGY~~, CYBERSECURITY AND PRIVACY PROTECTION REQUERIMENTS

- Cláusula 6 y en un par de notas tiene un impacto mínimo en las estrategias de implementación (La redacción de la cláusula 6.1.3 d) se reorganiza para eliminar la posible ambigüedad.)
- El cambio más significativo se encuentra en el Anexo A, que se asignará a los controles establecidos en ISO/IEC 27002:2022
- No se obliga a implementar los controles en el Anexo A; el requisito es que la organización seleccione los controles de cualquier fuente que considere apropiada y, para que estén completos, mapee esos controles en el Anexo A y justifique la omisión de cualquiera que no esté implementado
- La transición a ISO/IEC 27001:2022 solo requerirá un esfuerzo mínimo, y la fecha límite de transición no será hasta finales de 2024.
- Simple como cambiar su Declaración de aplicabilidad para mapear los controles de 2022 contra los controles de 2022, y ese mapeo ya está establecido en ISO/IEC 27002:2022.

UP Universidad de Palermo

NUESTRA INFORMACIÓN SE RELACIONA EN GRAN MEDIDA CON NUESTRAS OPERACIONES EJECUTIVAS, INTERACCIONES CON CLIENTES Y TERCEROS, DE DISTINTAS FORMAS Y A TRAVÉS DE NUMEROSOS MEDIOS



LA MAYOR PARTE DE NUESTRA INFORMACIÓN NO ESTÁ DISPONIBLE AL PÚBLICO EN GENERAL

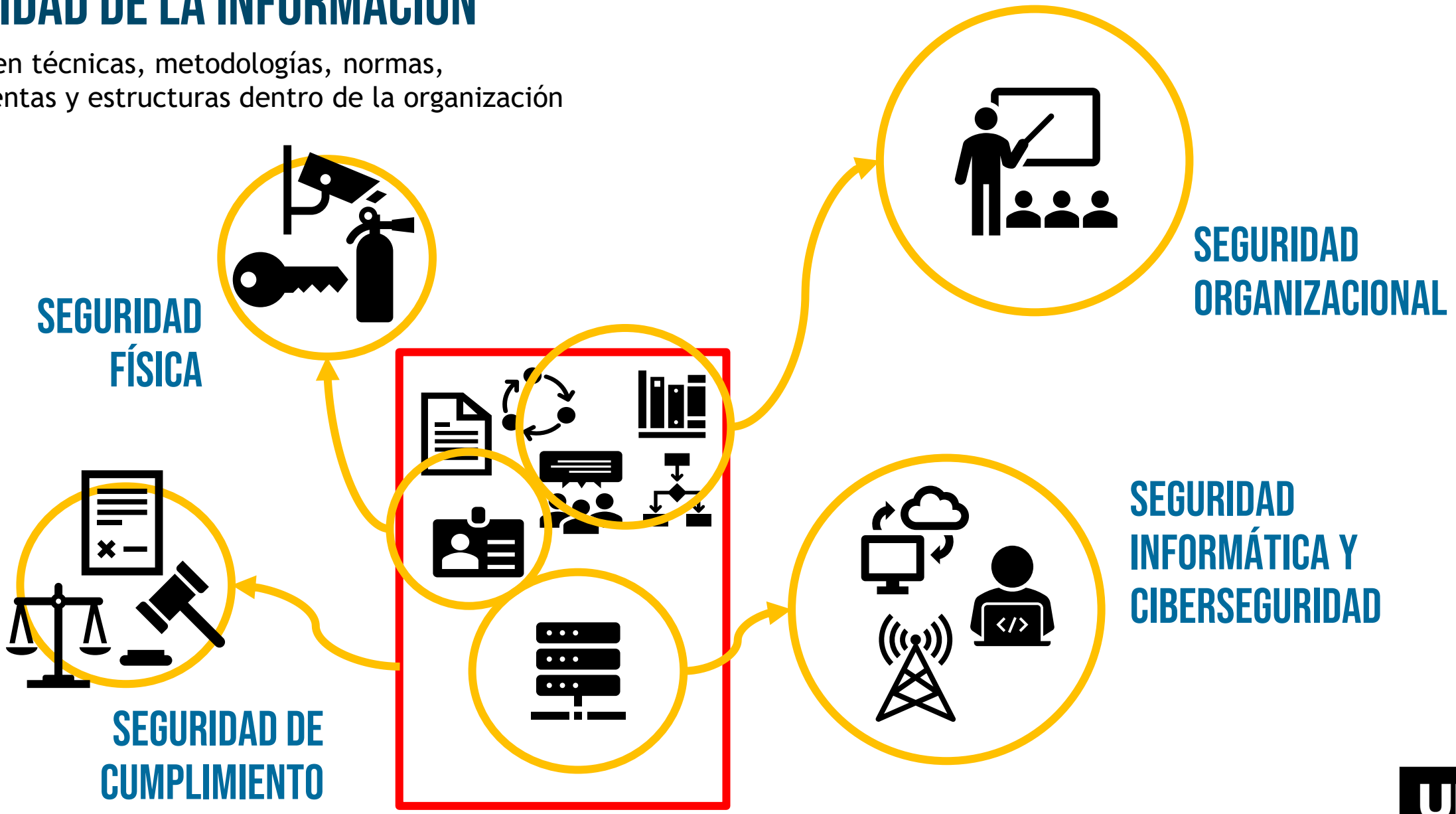
¿ESTA PERSONA NECESITA CONOCER ESTA INFORMACIÓN?

NECESIDAD DE CONOCER



SEGURIDAD DE LA INFORMACIÓN

Se basa en técnicas, metodologías, normas, herramientas y estructuras dentro de la organización



UP Universidad de Palermo

ENTORNO DE SEGURIDAD DE LA INFORMACIÓN



ORGANIZACIONAL
Establece el marco formal de seguridad que debe sustentar la Organización, incluyendo servicios o contrataciones externas a la infraestructura de seguridad, Integrando el recurso humano con la tecnología

FÍSICA
Identifica los límites mínimos que se deben cumplir en cuanto a perímetros de seguridad y acceso físico con base en la importancia de los activos.

LÓGICA
Establece e integra los mecanismos y procedimientos, que permitan monitorear el acceso informatizado a los activos de información

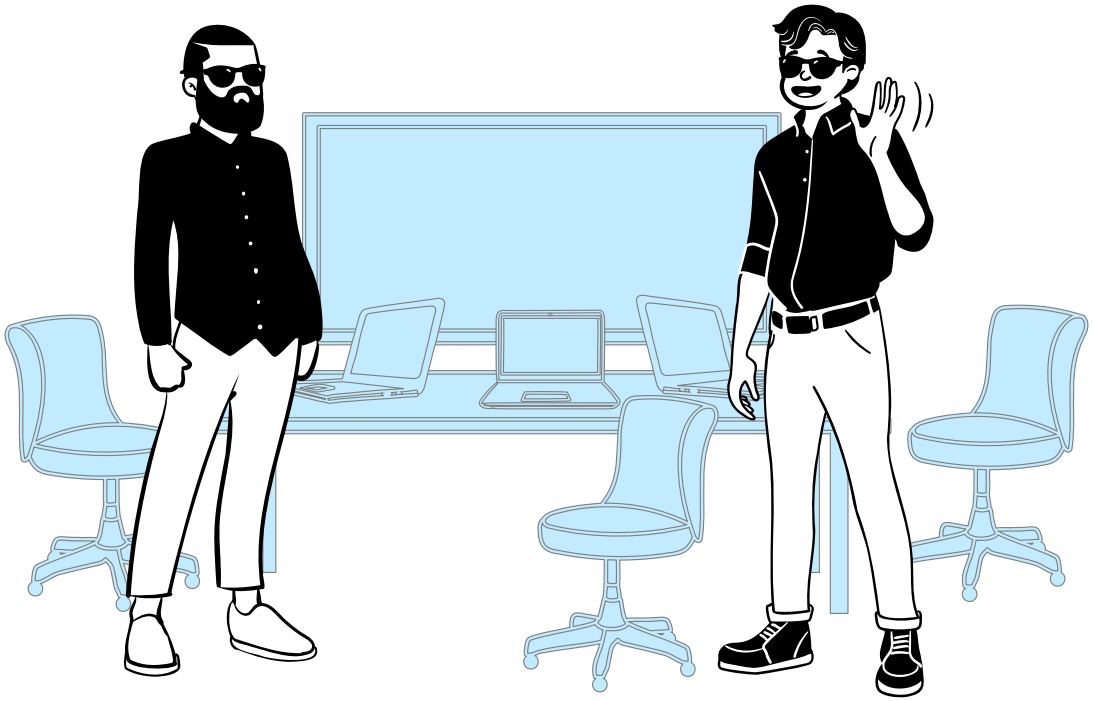
LEGAL
Integra los requerimientos de seguridad que deben cumplir todos los empleados, socios y usuarios de la red corporativa bajo la reglamentación de la normativa interna de políticas y manuales de procedimientos de la Organización

UP Universidad de Palermo

SEGURIDAD DE LA INFORMACIÓN ES UN PROCESO, NO UN ÁREA → COMPROMISO Y TRABAJO EN EQUIPO



- USUARIOS: **Propietario** (valorar el riesgo, asegurar concientización, apoyar controles, aprobar el uso, etc.) y el **custodio** (buen uso de datos y recursos, aplicar controles, reportar incidentes, etc.)



- ÁREAS TECNOLÓGICAS: **Sistemas y Tecnología** (aplicar controles, monitorear sistemas y red, asegurar dispositivos, etc.) y **Seguridad de la Información** (concientizar, definir políticas, establecer controles, gestionar incidentes, etc.)

UP Universidad de Palermo



MARCO LEGAL Y DE NEGOCIO

Qué debe cumplirse



ESTÁNDARES

Bajo que parámetros



RESPUESTA

Cómo debe cumplirse



BASE DE CUMPLIMIENTO

UP Universidad de Palermo



UP
Universidad
de Palermo

CREENCIAS



Pensábamos que no necesitábamos documentar nada, porque utilizábamos metodologías ágiles

Se fue un desarrollador y no sabemos como hizo parte del sistema

¿TRANSFERENCIA DEL CONOCIMIENTO?

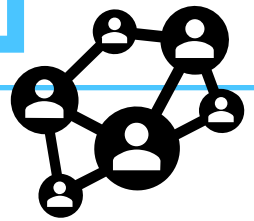
¿COMO CREAMOS CULTURA?

UP Universidad de Palermo



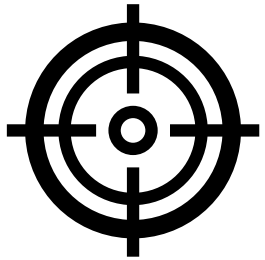
- **DIRECCIÓN**: Dirección estratégica, liderar y apoyar la implementación de las políticas y directrices, aprueba recursos y responsabilidades frente a riesgos y para la operación, verifica y aprueba las directrices de la seguridad en la información.

POLÍTICA DE SEGURIDAD
de la información



ALCANCE

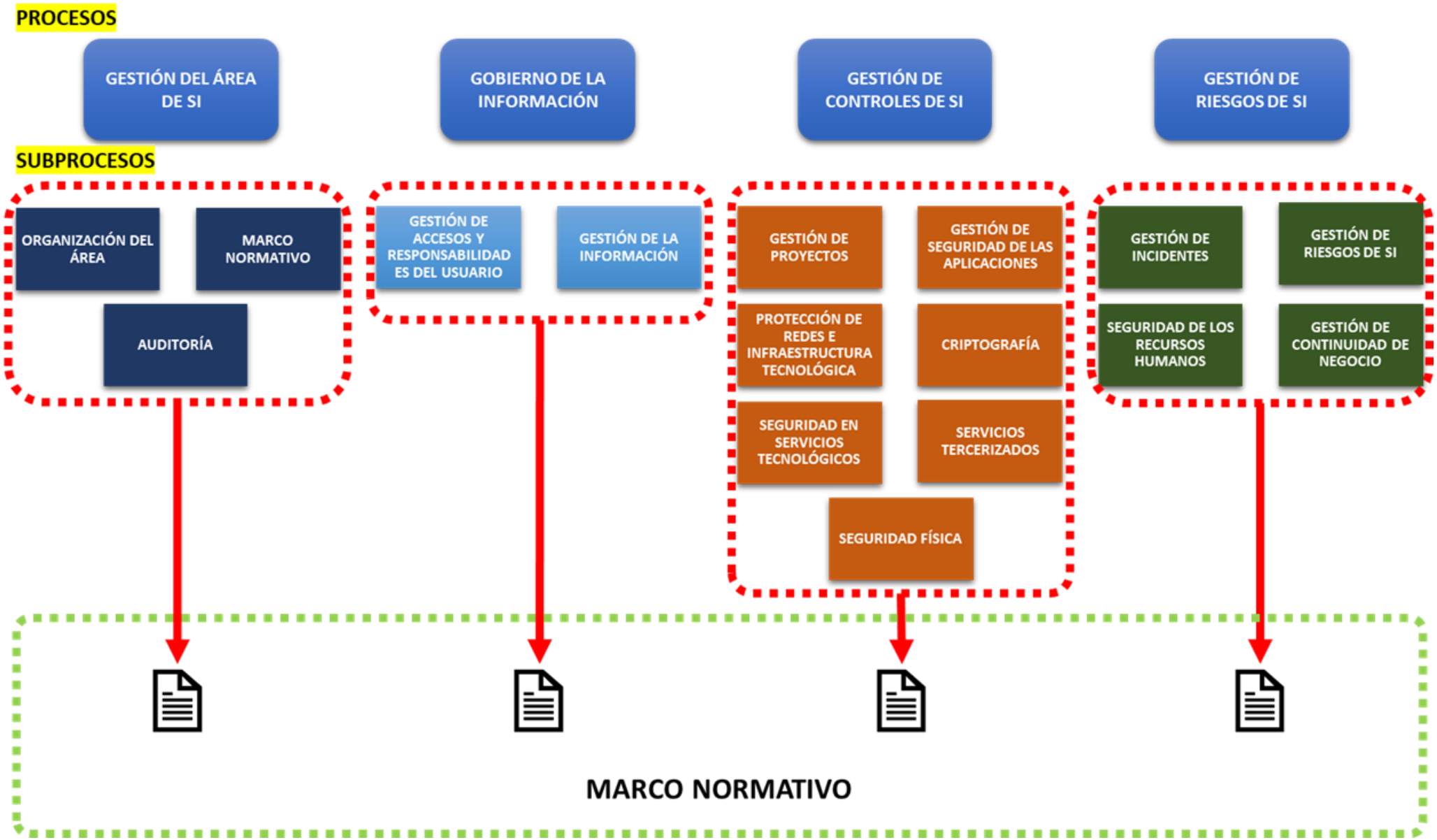




OBJETIVOS

- **CONFIDENCIALIDAD**: Información protegida del uso no autorizado, revelaciones, violación de la privacidad y otras acciones similares de accesos de terceros no permitidos.
- **INTEGRIDAD**: Información inalterable y completa.
- **DISPONIBILIDAD**: Información disponible para los usuarios que tengan los permisos adecuados, toda vez que lo requieran.

UP Universidad de Palermo

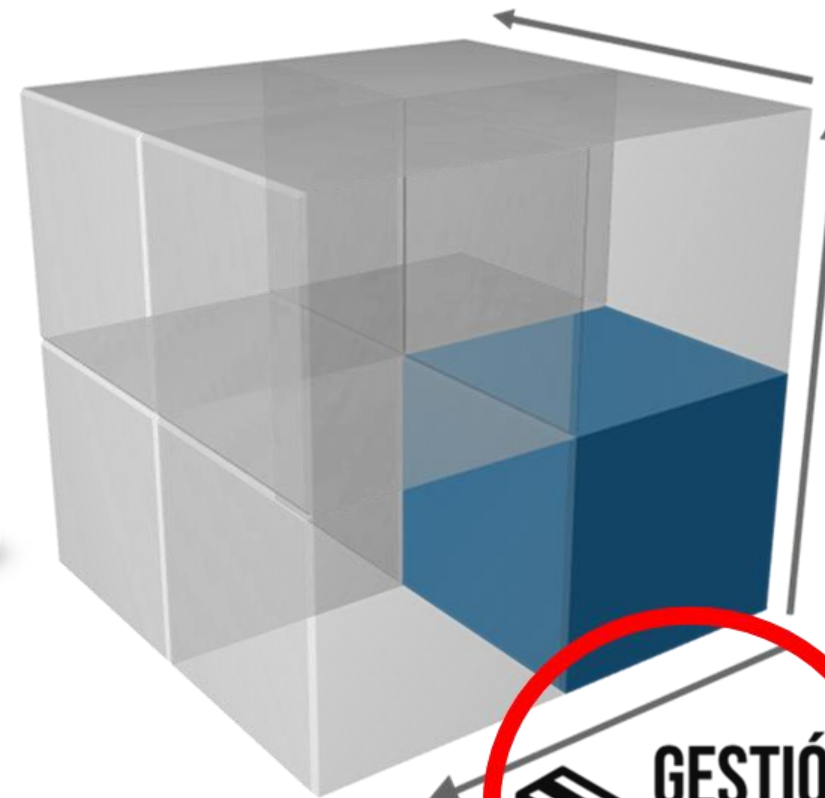


UP Universidad de Palermo

PLANIFICACIÓN ESTRATÉGICA Y GRADO DE INNOVACIÓN



CUBO DEL GOBIERNO TECNOLÓGICO



TECNOLOGÍA

Grado de innovación en el desarrollo tecnológico (tecnologías y procesos de producción)

ENTORNO

Grado de innovación en lo requerido para el crecimiento del negocio

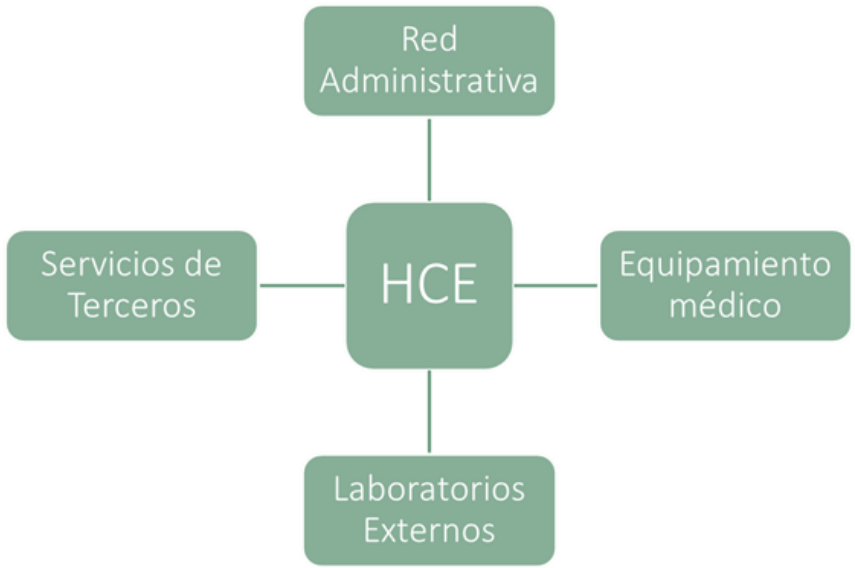
GESTIÓN

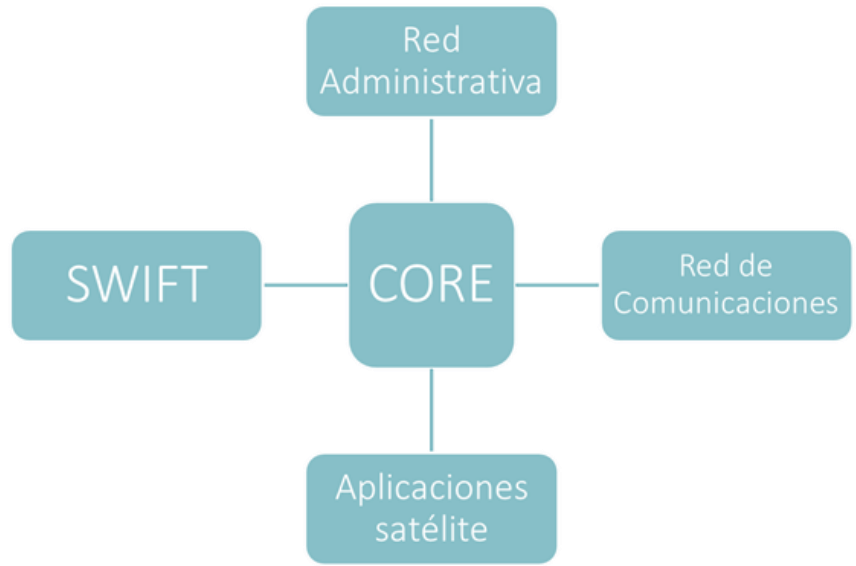
Grado de innovación necesaria en la gestión para el desarrollo del negocio

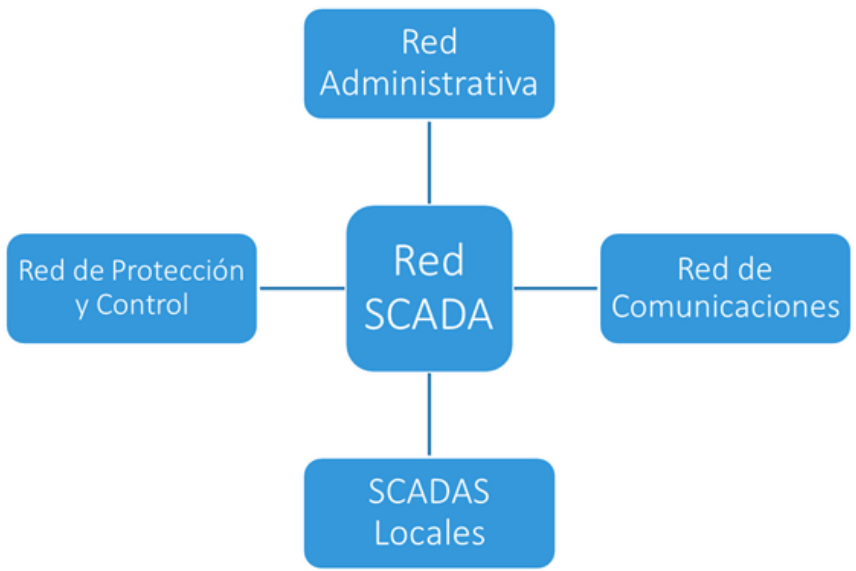
AMENAZAS EN LA TRANSFORMACIÓN DIGITAL Y USO DE NUEVAS METODOLOGÍAS

UP Universidad de Palermo

COMPLEJIDAD POR INDUSTRIA

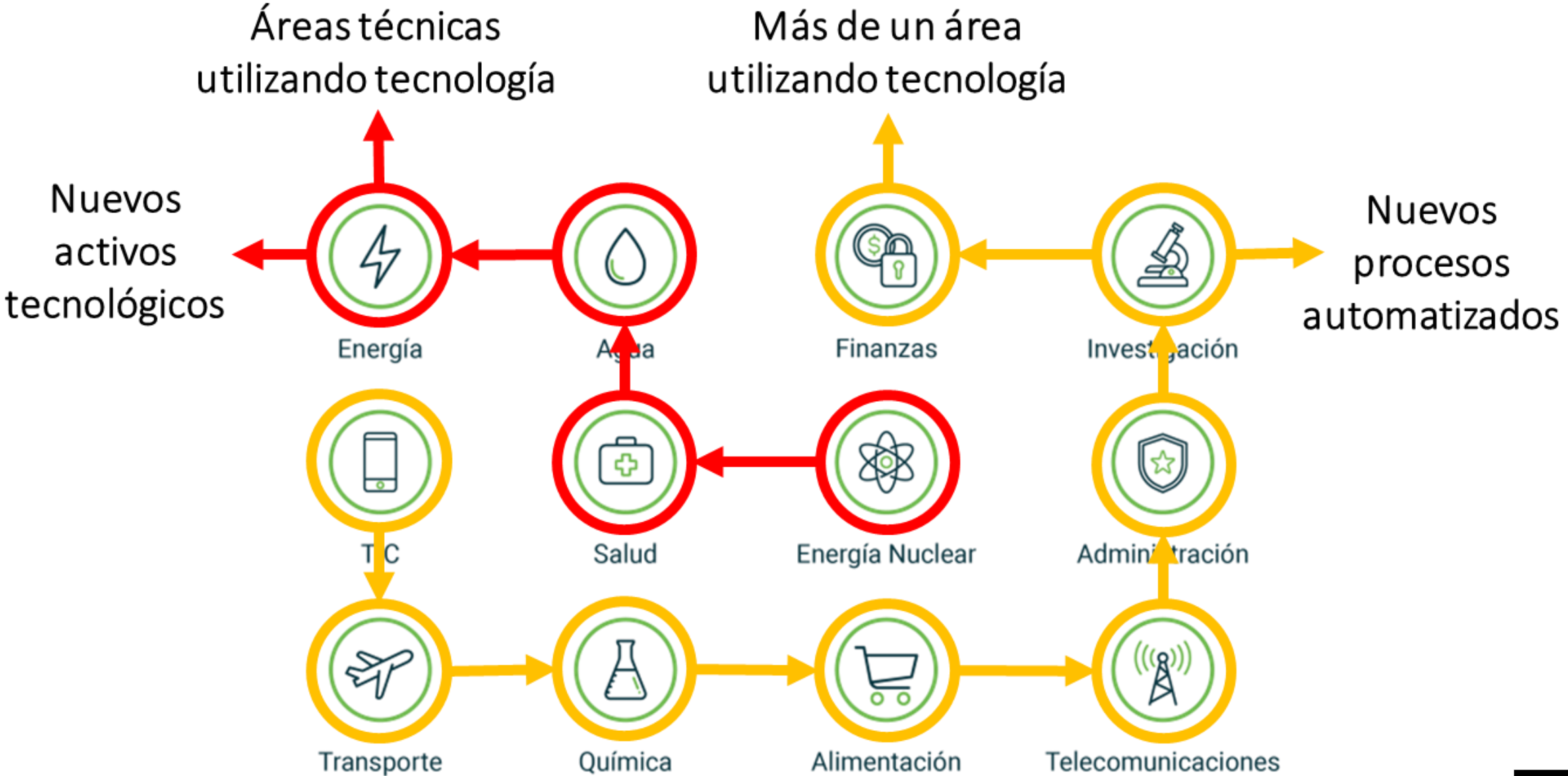






- Duplicidad de gestión y redes compartidas
- Problemática en interfaz entre ambientes
- Estandarización y duplicidad de gestión

UP Universidad de Palermo

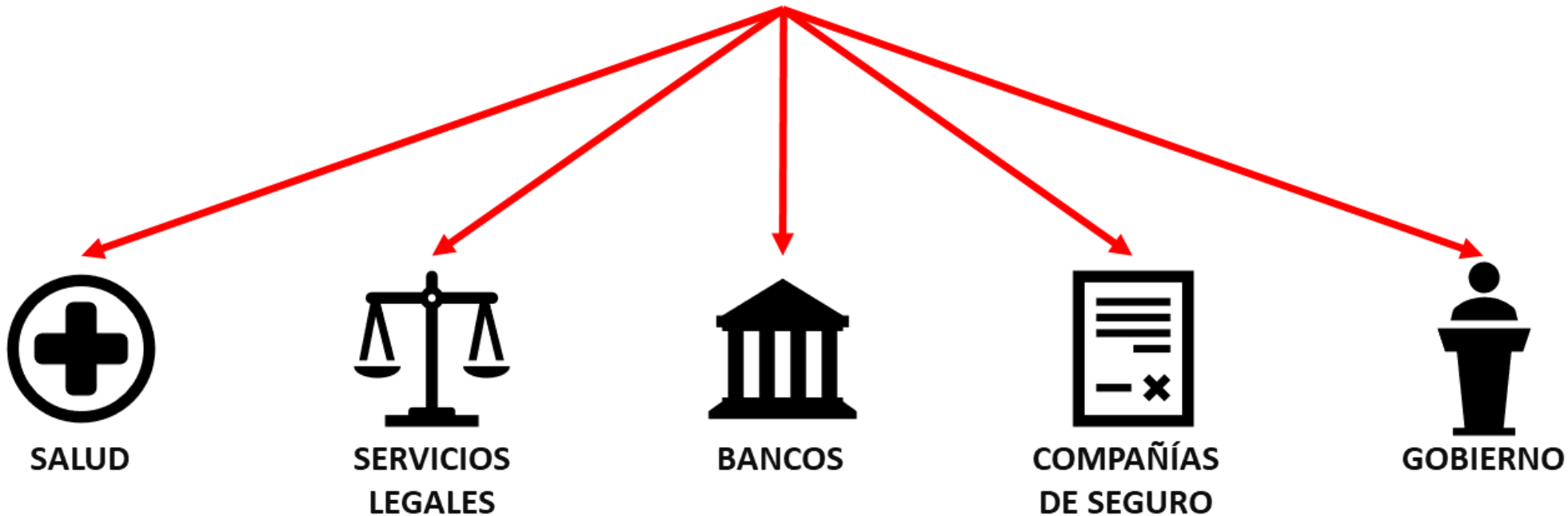


UP Universidad de Palermo

MAYOR DEPENDENCIA TECNOLÓGICA



CONVERSIÓN DE PROCESOS DE NEGOCIO



MAYOR DESAFÍO PARA LAS EMPRESAS REGULADAS

UP Universidad de Palermo

En 2020 los programas de transformación digital de las empresas experimentaron un **salto de más de cinco años para responder a la pandemia**



INDUSTRIAS QUE PUEDEN NO ESTAR PREPARADAS PARA EL FLUJO MASIVO DE TRABAJADORES REMOTOS

SALUD

SERVICIOS LEGALES

BANCOS

COMPAÑÍAS DE SEGURO

GOBIERNO

MAYOR DESAFÍO PARA LAS EMPRESAS REGULADAS

ROBO – SUPLANTACIÓN – DIVULGACIÓN → GDPR - PCI – BANCOS – HIPAA - SOX

https://www.checkpoint.com/press/2020/check-points-2020-cloud-security-report-highlights-enterprise-security-concerns-and-challenges-in-public-clouds/

UP Universidad de Palermo

MAYOR DEPENDENCIA TECNOLÓGICA



CONVERSIÓN DE PROCESOS DE NEGOCIO

CONSECUENCIAS Y RIESGOS FRENTE AL CAMBIO

Estratégico

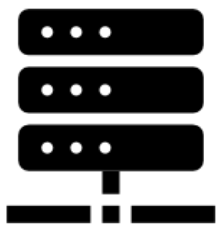
- Fallas del gobierno corporativo y control interno
- Rechazo interno al marco regulatorio
- Acciones legales o punitivas por falta de cumplimiento al marco regulatorio
- Incapacidad para atraer y retener conocimientos y competencias durante la transición

Operativo y Cumplimiento

- Administración ineficiente o fallas en la prestación de servicios internos y externos
- Débil seguridad de los datos y mayores riesgos de privacidad
- Riesgos en los procesos de servicio de TI y seguridad de la información
- Incapacidad de explotar y proteger activos (piratería y derechos de propiedad intelectual)
- Sistemas y procesos inadecuados para sustentar el negocio

UP Universidad de Palermo

Auditoría de Sistema de Información



CICLOS



Tecnología de información

Mayormente con riesgos asociados al acceso no autorizado y disponibilidad de la información



Depósitos / Gestión de Fondos

Mayormente observaciones con riesgo a la integridad de la información



Prevención de Lavado de Activos y Financiamiento del Terrorismo

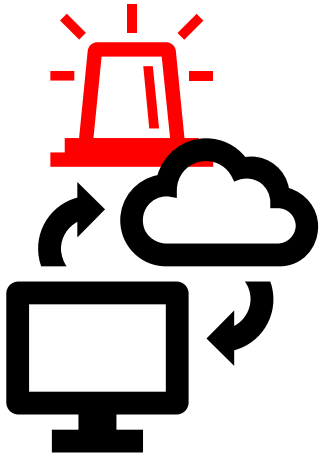
Falta de datos suficientes para una posible investigación y riesgos de administración en el control de accesos



Préstamos y Recupero de Deudas

Mayormente riesgos de integridad y completitud de información

UP Universidad de Palermo



Falta de documentación técnica para interfases aumenta el riesgo de errores ante un incidente funcional aplicativo

La falta de un proceso de análisis de procesos críticos y no revisar el entorno de seguridad física del centro alternativo, aumentan el riesgo de continuidad de negocio

Falta de ejecución de un plan o cronograma de reválida de usuarios

Falta de generación de aplicativos versionados y documentación de apoyo sin actualizar aumenta los riesgos de errores funcionales y de soporte

No hay un proceso integral para la gestión de servicios de TI, lo que aumenta el riesgo en los procesos de servicios tecnológicos y en el cumplimiento

UP Universidad de Palermo

Auditoría participar desde el inicio

Favorece a construir controles eficientes y eficaces

Favorece a construir un entorno auditable

Modelo de Negocio

Diseño del Servicio

Construcción del Servicio

MARCO CONTRACTUAL

Alcance de responsabilidad

Alcances del servicio

Alcance de los controles

- Gestión del servicio
- Tratamiento de datos
- Gestión de registros
- Gestión de componentes del servicio (Documentación, RRHH, recursos tecnológicos)

DISEÑO DE SERVICIOS TI | GESTIÓN DE PROYECTOS

- Usuarios del Servicio
- Patrones de uso
- Visión y alcance
- Diseño y Arquitectura
- Nivel de Servicio
- Montaje de Infraestructura
- Construcción de Software



- Capacidad y disponibilidad
- Continuidad
- Seguridad
- Análisis y diseño aplicativo
- HW y SFW de base
- Comunicaciones
- Desarrollo
- Pruebas

Definición de intervención de terceros

Identificación y gestión de terceros que acceden o procesan información, asegurando contratos, obligaciones y nivel de protección adecuado.

Ciberresiliencia / resiliencia tecnológica

Asegurar la continuidad del servicio, la protección de la información y la recuperacido ante eventos que puedan afectar la operación.

Soluciones de software para compañías de seguros

PRIVACIDAD Y SEGURIDAD COMO EJES TRANSVERSALES

- Protección de datos personales y sensibles desde el diseño (Privacy by Design).
- Cumplimiento normativo y contractual en cada etapa del ciclo de vida del servicio.
- Transparencia y responsabilidad en el uso y tratamiento de la información.
- Controles de seguridad alineados a riesgos y mejores prácticas (ISO 27001, NIST, COBIT).
- Trazabilidad, monitoreo y mejora continua para garantizar la confianza y la auditoría.

RESULTADO ESPERADO

Servicios TI confiables, seguros, resilientes y alineados al negocio, que protegen la información y generan valor sostenible.

GOBIERNO DE CIBERTECNOLOGÍA Y CIBERSEGURIDAD

La ciberseguridad como riesgo estratégico

1 PLAN DE NEGOCIO

GESTIÓN DE PROYECTOS

GESTIÓN DE RIESGOS

Identificar y evaluar riesgos que puedan afectar los objetivos del negocio.

GESTIÓN DEL CAMBIO

Asegurar que los cambios en procesos, tecnología y organización se realicen de forma controlada.

GESTIÓN DE INCIDENTES

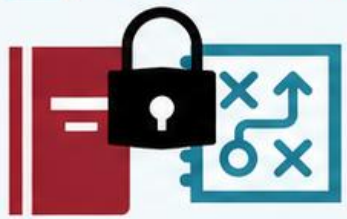
Detectar, respnolgér y resolver incidentes para minimizar su impacto en el negocio.

2 PLAN DE SISTEMAS



Alinear la tecnología y los sistemas de información con los objetivos del negocio.

3 PLAN DE SEGURIDAD



Definir controles, políticas y prácticas de seguridad para proteger los activos de información y asegurar la continuidad del negocio.

4 GESTIÓN DE PROYECTOS



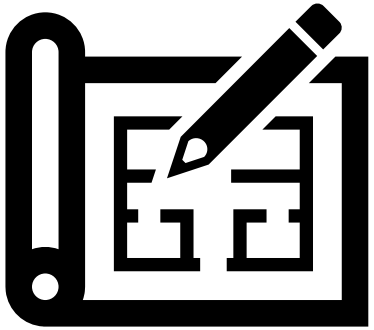
Ejecutar proyectos que generen valor al negocio, cumplan los objetivos estratégicos y fortalezcan la ciberseguridad organizacional.

MEJORA CONTINUA

La seguridad debe entenderse como un proceso de mejora de la calidad en una organización, con el objetivo de mejorar continuamente el rendimiento organizacional.

BDO

PRINCIPALES DESVÍOS A TENER EN CUENTA



GESTIÓN DE PROYECTOS



IMPULSAR Y SUPERVISAR

Directorio

ASEGURAR LA INCORPORACIÓN DE SEGURIDAD Y PRIVACIDAD DESDE EL DISEÑO.

Alta Gerencia





Tercerización de servicios tecnológicos



Complejidad de la tecnología aplicada al negocio



Falta de estandarización de la ciberseguridad y la gestión de IT



Mayor dependencia de las TICs e influencia del Shadow IT



Vulnerabilidades técnicas y administrativas de sistemas

UP Universidad de Palermo

RIESGOS DE TERCEROS TECNOLÓGICOS

Trabajar con terceros tecnológicos amplía nuestras capacidades, pero también nuestra superficie de riesgo.

CONÓCELOS, GESTIÓNALOS Y PROTÉGETE.

¿QUÉ ES UN TERCERO TECNOLÓGICO?

Cualquier proveedor externo que accede, procesa, almacena o tiene visibilidad sobre información, sistemas o infraestructura de nuestra organización.



PRINCIPALES RIESGOS

ACCESO NO AUTORIZADO
Accesos indebidos a sistemas o datos por parte de terceros o sus empleados.

VULNERABILIDADES Y CONFIGURACIONES INSEGURAS
Deficiencias en la seguridad del tercero que pueden ser explotadas para comprometer nuestra información.

PÉRDIDA O FILTRACIÓN DE DATOS
Exposición, pérdida o uso indebido de información confidencial o sensible.

INTERRUPCIÓN DEL SERVICIO
Fallos, incidentes o quiebres operativos del tercero que impactan la disponibilidad de nuestros servicios.

INCUMPLIMIENTO LEGAL Y NORMATIVO
Incumplimientos del tercero que pueden generar sanciones, multas o daño reputacional para nuestra organización.

RIESGOS REPUTACIONALES
Conductas indebidas, incidentes o malas prácticas del tercero que afectan nuestra imagen y la confianza de clientes y partes interesadas.

¿CÓMO SE MATERIALIZAN?

A lo largo de todo el ciclo de relación con el tercero pueden surgir riesgos que afecten nuestra seguridad de la información.



1. EVALUAR
Selección inadecuada de proveedores sin evaluar sus controles de seguridad.

2. CONTRATAR
Cláusulas contractuales insuficientes o poco claras sobre seguridad y privacidad.

3. INTEGRAR
Conexiones y accesos con privilegios excesivos o sin controles adecuados.

4. OPERAR
Monitoreo insuficiente del desempeño y seguridad del tercero.

5. FINALIZAR
Cierre inadecuado de accesos y no eliminación segura de la información.

CÓMO GESTIONAR LOS RIESGOS

DILIGENCIA DEBIDA
Evalúa la madurez de seguridad, cumplimiento, historial e infraestructura del tercero antes de establecer la relación.

CONTRATOS Y ACUERDOS SÓLIDOS
Define responsabilidades, requisitos de seguridad, confidencialidad, gestión de incidentes, continuidad y derechos de auditoría.

PRINCIPIO DE MÍNIMO PRIVILEGIO
Otorga solo los accesos y datos estrictamente necesarios para la prestación del servicio.

MONITOREO CONTINUO
Supervisa el desempeño, disponibilidad, vulnerabilidades e incidentes del tercero de forma continua.

GESTIÓN DE INCIDENTES COORDINADA
Establece canales de comunicación y tiempos de respuesta claros ante incidentes de seguridad.

FINALIZACIÓN SEGURA
Asegura la revocación de accesos y la eliminación o devolución segura de la información y activos.

MEJORES PRÁCTICAS

- Clasifica a los terceros según el nivel de riesgo.
- Alinea los requisitos con estándares y marcos de seguridad (ISO 27001, NIST, CIS, etc.).
- Capacita a los equipos sobre la gestión de terceros y cultura de seguridad.
- Realiza auditorías y revisiones periódicas a terceros críticos.
- Mantén un inventario actualizado de todos los terceros y servicios contratados.

RECUERDA

La seguridad de la información es una responsabilidad compartida. Un tercero con procesos débiles puede convertirse en el eslabón más débil de nuestra cadena de seguridad.

GESTIONA EL RIESGO. PROTEGE TU INFORMACIÓN.

ISO/IEC 27016

Gestión de la Economía de la Seguridad de la Información

Marco de referencia para evaluar, justificar y comunicar el valor de las iniciativas de seguridad de la información desde una perspectiva económica y de riesgo.



ENFOQUE ECONÓMICO
Incorpora principios económicos en la toma de decisiones de seguridad para optimizar el uso de recursos.

DECISIONES BASADAS EN VALOR
Permite comparar alternativas de control y priorizar inversiones según el valor que aportan al negocio.

TRANSPARENCIA Y COMUNICACIÓN
Facilita el diálogo con la alta dirección y otras áreas del negocio utilizando un lenguaje financiero común.

ALINEACIÓN CON EL RIESGO
Vincula costo, riesgo y valor para apoyar una gestión de riesgos más eficaz y sostenible.

¿QUÉ ES ISO/IEC 27016?

ISO/IEC 27016 proporciona directrices para integrar principios y técnicas económicas en la gestión de la seguridad de la información.

No establece requisitos, sino un marco conceptual y un conjunto de procesos para apoyar decisiones informadas sobre inversiones y controles de seguridad.

PRINCIPIOS CLAVE

ORIENTACIÓN AL NEGOCIO
La seguridad debe aportar valor y respaldar los objetivos estratégicos.

EFICIENCIA ECONÓMICA
Optimizar la relación entre beneficios, costos y riesgos.

EVIDENCIA Y OBJETIVIDAD
Decisiones basadas en datos, métricas y análisis cuantitativos o cualitativos.

TRANSPARENCIA
Comunicar claramente supuestos, métodos y resultados a las partes interesadas.

MEJORA CONTINUA
Revisar y actualizar evaluaciones económicas en función del contexto y la evolución del riesgo.

¿PARA QUIÉN ES ÚTIL?

- Alta Dirección y Gobierno Corporativo
- CISO y Equipos de Seguridad
- Finanzas y Risk Management
- Auditores y Consultores
- Cualquier área que toma decisiones sobre inversiones en seguridad

MARCO DE TRABAJO DE ISO/IEC 27016

El estándar propone un proceso estructurado para incorporar consideraciones económicas en la gestión de la seguridad, acompañando todo el ciclo de vida de una decisión.

01 ESTABLECER EL CONTEXTO
- Comprender el negocio, los objetivos y el entorno.
- Definir el alcande y los criterios de decisión.

02 IDENTIFICAR ALTERNATIVAS
- Identificar opciones de tratamiento del riesgo.
- Incluir controles existentes y nuevas iniciativas.

03 ANALIZAR COSTOS Y BENEFICIOS
- Estimar costos de implementación y operación.
- Estimar beneficios tangibles e intangibles.

04 EVALUAR RIESGOS
- Analizar riesgos asociados a cada alternativa.
- Considerar probabilidad e impacto.

05 COMPARAR Y RECOMENDAR
- Comparar alternativas con base en valor neto.
- Recomendar la opción óptima.

06 MONITOREAR Y MEJORAR
- Monitorear resultados reales vs. esperados.
- Ajustar decisiones y supuestos.



Seguridad que genera valor.
Decisiones que protegen el negocio.

FAIR
Factor Analysis of Information Risk

El lenguaje financiero para tomar mejores decisiones sobre ciber riesgos.

FAIR es un modelo analítico estándar que permite identificar, analizar y cuantificar el riesgo de seguridad de la información en términos financieros, para apoyar decisiones más informadas, proporcionales y alineadas al negocio.





¿POR QUÉ FAIR?

- Traduce el riesgo técnico a impacto financiero.
- Permite priorizar inversiones y controles.
- Facilita la comunicación con la alta dirección y el directorio.
- Soporta una gestión de riesgos basada en datos y no en suposiciones.

EL MÉTODO FAIR: MARCO Y COMPONENTES

FAIR analiza el riesgo a través de dos componentes principales: la frecuencia de los eventos de pérdida y el impacto financiero si esos eventos ocurren.

OBJETIVO

Estimar la Pérdida Anual **Esperada (ALE)** para cada escenario de riesgo.

1. FRECUENCIA DE PÉRDIDA

Tasa de Ocurrencia de Amenaza (TEF)
¿Con qué frecuencia puede ocurrir una amenaza?

Probabilidad de Evento de Pérdida (LEP)
¿Qué probabilidad hay de que esa amenaza explote una vulnerabilidad y cause una pérdida?

FRECUENCIA ANUAL DE PÉRDIDA (ARO)
Frecuencia esperada de eventos de pérdida en un año.

ARO = TEF × LEP

2. MAGNITUD DE LA PÉRDIDA

Pérdida Primaria (SLE)
Impacto financiero directo generado por el evento (ej. costos de respuesta, recuperación, multas).

Pérdida Secundaria (RLE)
Consecuencias indirectas (ej. daño reputacional, pérdida de clientes, ingresos futuros).

MAGNITUD ANUAL DE PÉRDIDA (ALE Magnitude)
Valor monetario esperado de las pérdidas en un año.

ALE Magnitude = SLE + RLE

3. PÉRDIDA ANUAL ESPERADA

ALE = ARO × ALE Magnitude

Es el valor económico esperado de las pérdidas por riesgo en un año.

¿QUÉ OBTIENE LA ORGANIZACIÓN?

- Una estimación financiera del riesgo.
- Comparación entre riesgos y escenarios.
- Priorización objetiva de controles.
- Justificación económica de inversiones en seguridad.

FAIR EN LA PRÁCTICA: DE DATOS A DECISIONES

FAIR convierte datos técnicos y de negocio en información financiera útil para decidir cuánto invertir y dónde enfocar los esfuerzos.

1. DATOS DE ENTRADA
- Inteligencia de amenazas
- Vulnerabilidades
- Historial de incidentes
- Datos del negocio y financieros

2. MODELO FAIR

3. RESULTADOS
- ALE por escenario de riesgo
- Riesgos Top y contribuyentes
- Comparación de opciones de tratamiento
- Reporte para el Directorio y stakeholders

EJEMPLO SIMPLIFICADO

ESCENARIO DE RIESGO	TEF	LEP	ARO	SLE	RLE	ALE MAGNITUDE	ALE
Ransomware que cifra servidores críticos	0,40 por año	15%	0,06 por año	USD 800.000	USD 400.000	USD 1.200.000	**USD 72.000 por año**

INTERPRETACIÓN
Se espera una pérdida promedio de USD 72.000 por año debido a este riesgo.
Con esta información, la organización puede decidir si ese nivel de riesgo es aceptable o si conviene invertir en controles que lo reduzcan.

DECISIÓN INFORMADA
Invertir kasta un monto inferior al beneficio esperado de reducir el riesgo.

FAIR no elimina la incertidumbre, la mide y la convierte en una ventaja competitiva.

Menos suposiciones. Más evidencia. Mejores decisiones.

MARCO DE CONTROL INTERNO COSO

Marco Integrado de Control Interno

COSO (Committee of Sponsoring Organizations of the Treadway Commission) proporciona un **marco de referencia** para diseñar, implementar y evaluar un sistema de control interno eficaz.

¿QUÉ ES COSO?

Es un marco de buenas prácticas reconocido internacionalmente que ayuda a las organizaciones a lograr sus objetivos, gestionar riesgos y mejorar el desempeño mediante un sistema de control interno efectivo.

¿CUÁL ES SU PROPÓSITO?

Proporcionar una estructura y principios que permitan a las organizaciones mejorar su gobierno corporativo, gestión de riesgos y procesos de control, generando razonable seguridad en el logro de sus objetivos.

¿QUÉ OBJETIVOS BUSCA ALCANZAR?

Objetivos de Operación

Lograr operaciones eficaces, eficientes y económicas, incluyendo metas de desempeño y rentabilidad.

Objetivos de Información

Asegurar la confiabilidad, oportunidad y transparencia de la información financiera y no financiera.

Objetivos de Cumplimiento

Cumplir con las leyes, regulaciones, políticas internas y demás compromisos asumidos por la organización.

LOS 5 COMPONENTES DEL CONTROL INTERNO

COSO agrupa el control interno en 5 componentes interrelacionados.



1. AMBIENTE DE CONTROL

Establece el tono de la organización. Incluye integridad, valores éticos, estructura organizacional, autoridad y responsabilidad.

2. EVALUACIÓN DE RIESGOS

Identifica y analiza riesgos que pueden afectar el logro de los objetivos y define cómo deben ser gestionados.

3. ACTIVIDADES DE CONTROL

Políticas y procedimientos que ayudan a asegurar que las respuestas a los riesgos se lleven a cabo eficazmente.

4. INFORMACIÓN Y COMUNICACIÓN

La información relevante se identifica, captura y comunica de forma oportuna y adecuada en toda la organización.

5. ACTIVIDADES DE MONITOREO

Evaluaciones continuas o periódicas para asegurar que los cinco componentes estén presentes y funcionando.

17 PRINCIPIOS FUNDAMENTALES

Cada componente se sustenta en principios que guían su diseño y operación.

¿QUÉ BENEFICIOS GENERA?

- Mejora la gestión de riesgos y la toma de decisiones.
- Aumenta la eficiencia operativa.
- Fortalece la confiabilidad de la información.
- Promueve el cumplimiento normativo.
- Genera confianza en stakeholders e inversionistas.

EN RESUMEN

El marco COSO no es solo para auditores: es una guía práctica para todos los líderes y equipos que buscan alcanzar sus objetivos con integridad y confianza.

- Proporciona una visión integral del control interno.
- Es flexible y adaptable a cualquier tipo y tamaño de organización.
- Debe evolucionar junto con el entorno y los riesgos del negocio.
- El buen control interno impulsa el logro sostenible de los objetivos.

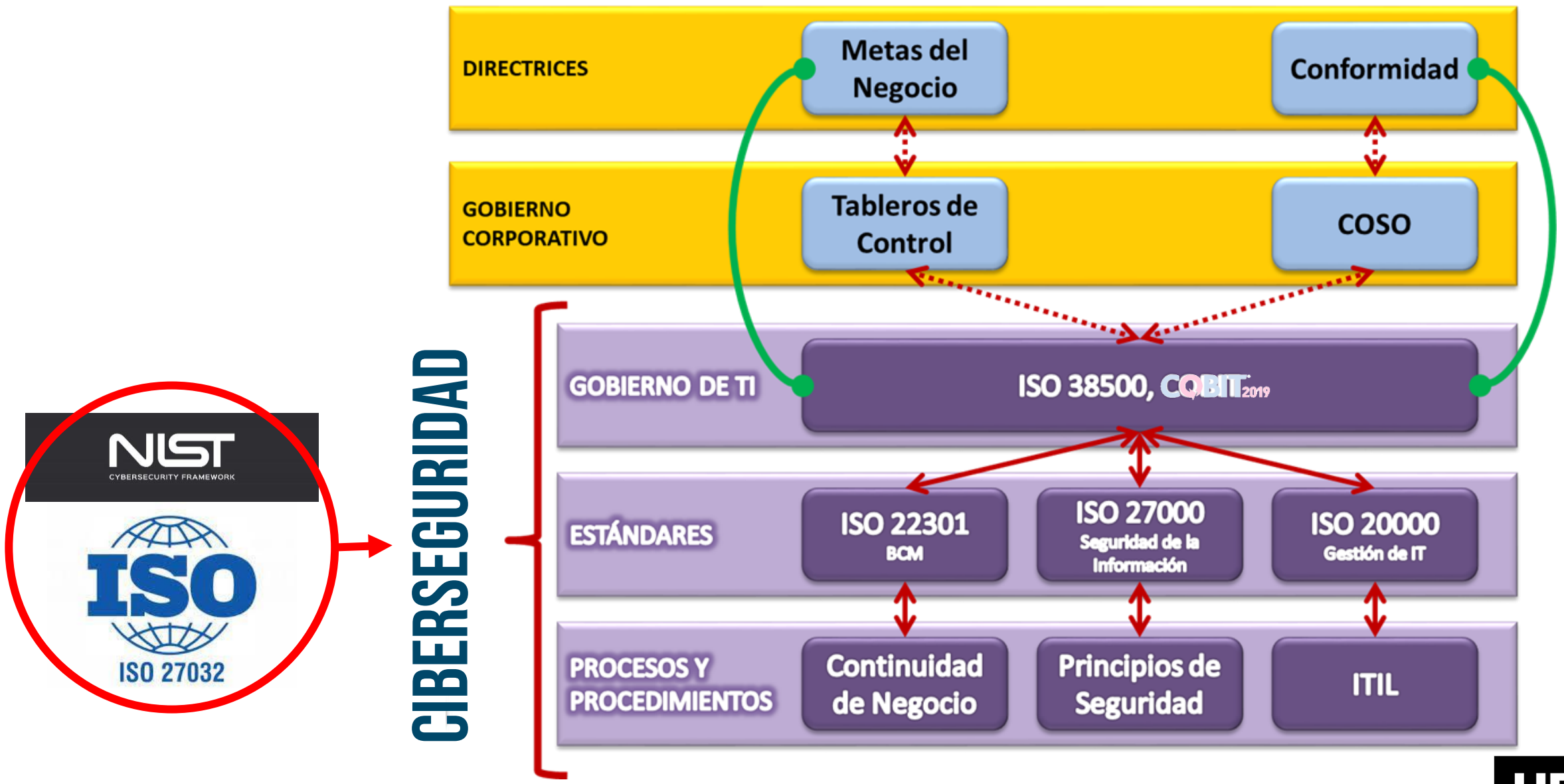
COSO

Control Interno
Gobierno Corporativo

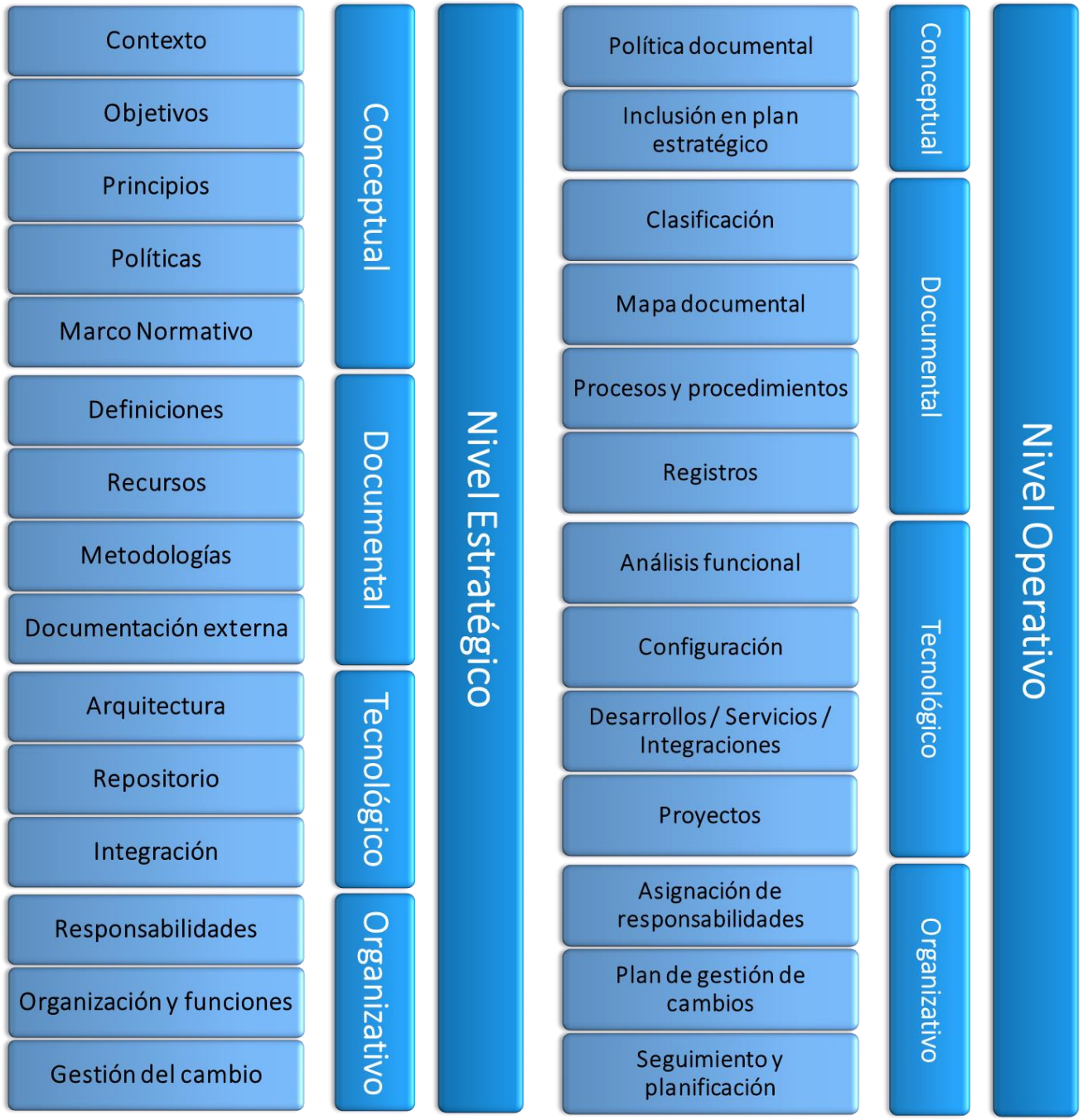
Seguridad de la información como área de control en la segunda línea de defensa, dependiendo directamente de la dirección



UP Universidad de Palermo



UP
Universidad de Palermo



Gestión y automatización del marco documental

Comprendiendo nuestro contexto

El propósito de la documentación es enseñar a quienes no están familiarizados con un proceso cómo este se estructura, funciona, sus necesidades de cumplimiento y los motivos que llevaron al diseño del proceso

UP Universidad de Palermo

Mejora de la Calidad

•Estándares de Calidad

- Aseguramiento de productos y servicios de alta calidad.
- Reducción de errores y defectos.

•Certificaciones y Reconocimientos

- ISO 9001, otros certificados relevantes.

Reducción de Riesgos

•Cumplimiento Legal

- Evitación de sanciones y multas.
- Cumplimiento con leyes y regulaciones.

•Seguridad y Salud

- Normativas de seguridad laboral.
- Protección del medio ambiente.

Satisfacción del Cliente

•Mejora en la Experiencia del Cliente

- Productos y servicios confiables.
- Implementación de mejores prácticas.
- Respuesta efectiva a las necesidades del cliente.

•Fidelización del Cliente

- Aumento de la lealtad del cliente.
- Recomendaciones y referencias.

Ventajas Competitivas

•Acceso a Nuevos Mercados

- Cumplimiento con regulaciones internacionales.
- Oportunidades de exportación.
- Estándares que promueven la innovación.

•Reputación y Confianza

- Imagen positiva ante clientes y socios.

UP Universidad de Palermo

Optimiza el **tiempo** dedicado a la gestión



Menos de tiempo de resolución de una acción correctiva



Menos de tiempo de preparación de las reuniones de gestión



Menos de tiempo de preparación de las reuniones de gestión

Reduce los **costos** y supone una inversión rentable



Menos intercambios de documentación física entre áreas.



Menos de costes indirectos derivados de la gestión documental



La inversión se rentabiliza entre el primer y el segundo año.

Aumenta el **rendimiento** de la organización



Más de optimización en el sistema de gestión tras la etapa de consultoría



Más capacidad de resolución de problemas del sistema de gestión



Más colaboración, compromiso e implicación del personal

UP
Universidad de Palermo

“Una vez más, pensar corporativamente es el principio de la solución para alcanzar un nivel aceptable de gobierno del negocio apoyado en su documentación, sin hacerlo disruptivo, pero si asegurando sus resultados”





UP
Universidad
de Palermo